



VIAIKON[®]

Innovamos con energía

Benites Rangel Cesar Yahir - 179091
Cortes Beltrán Carol Elizabeth - 177203
Guerra Ramírez América Fabiola - 179888
Larios Guerra Gustavo Michael - 178318
Montelongo Martínez Laura Ivon - 177291
Puente Luna Bruno Axel - 177876
Rodríguez Moreno Cristian Alejandro - 181641

SECCIÓN 1 - Alcance	6
Objetivo del alcance.....	6
Ámbito de Aplicación (Administración y TI).....	6
Acerca de la Empresa.....	6
¿Quiénes somos?.....	6
Un poco de nuestra historia.....	7
Sitio web.	7
Misión	7
Visión.....	7
Objetivos Organizacionales.	8
Ética y Valores	8
Planeta.....	8
Nuestra gente	8
Comunidad.....	8
Reconocimientos y Certificaciones.....	8
Política de Calidad Viakon	9
Políticas Xignux.....	9
Política de Calidad, Ambiental, Salud y Seguridad	9
Estructura General del Organigrama.....	11
Área de Administración / TI	11
SECCIÓN 2 - Referencias Normativas.....	12
2.1 Norma Base del SGSI	12
2.2 Familia ISO/IEC 27000: Controles y Gestión de Riesgos	12
2.3 Normas Complementarias	13
2.4 Referencias Bibliográficas	13
SECCIÓN 3 - Términos y Condiciones	14
1. Aceptación del riesgo (Risk acceptance)	14
2. Activo (Asset)	14
3. Alta dirección (Top management)	14
4. Amenaza (Threat)	14
5. Análisis de riesgos (Risk analysis).....	14
6. Análisis de riesgos cualitativo (Qualitative risk analysis)	14
7. Análisis de riesgos cuantitativo (Quantitative risk analysis)	14
8. Ataque (Attack).....	14
9. Auditoría (Audit)	14
10. Auditor (Auditor)	14

11.	CID (CIA)	14
12.	Comunicación y consulta de riesgos (Risk communication and consultation)	14
13.	Confidencialidad (Confidentiality)	15
14.	Control (Control)	15
15.	Control de acceso (Access control).....	15
16.	Disponibilidad (Availability)	15
17.	Estimación de riesgos (Risk evaluation).....	15
18.	Evaluación de riesgos (Risk assessment).....	15
19.	Evento (Event)	15
20.	Evento de seguridad de la información (Information security event).....	15
21.	Gestión de incidentes de seguridad de la información (Information security incident management).....	15
22.	Gestión de riesgos (Risk management).....	15
23.	Identificación de riesgos (Risk identification)	15
24.	Impacto (Impact).....	15
25.	Incidente (Incident)	16
26.	Incidente de seguridad de la información (Information security incident)	16
27.	Indicador (Indicator)	16
28.	Información documentada (Documented information).....	16
29.	Integridad (Integrity).....	16
30.	Inventario de activos (Assets inventory).....	16
31.	ISO/IEC 27001.....	16
32.	Nivel de riesgo (Level of risk)	16
33.	Objetivo (Objective)	16
34.	Organización (Organization).....	16
35.	Plan de continuidad del negocio (Business Continuity Plan)	16
36.	Plan de tratamiento de riesgos (Risk treatment plan).....	16
37.	Rendimiento (Performance).....	17
38.	Riesgo (Risk)	17
39.	Sarbanes-Oxley (SOX)	17
40.	Seguridad de la información (Information security).....	17
41.	Sistema de Información (Information system).....	17
42.	Sistema de Gestión de Seguridad de la Información (SGSI / ISMS).....	17
43.	Tratamiento de riesgos (Risk treatment)	17
44.	Tratamiento del riesgo	17
45.	Vulnerabilidad (Vulnerability).....	17
	Condiciones de la Intervención (Acuerdo Operativo y Alcance)	17
	SECCIÓN 4 - Contexto de la organización	19

SECCIÓN 5 - Liderazgo.....	23
Política General de la Organización.....	23
Objetivo.....	23
Alcance de Aplicabilidad.....	23
Compromiso de la Dirección	23
Políticas Funcionales	23
Base de Datos.....	23
ERP Corporativo - SAP/Oracle.....	24
Software de Monitoreo de Red	24
Registros de Usuarios y Credenciales.....	24
Impresoras Empresariales	24
Equipos de Cómputo - Laptops.....	25
Herramientas de Administración Remota	25
Servidores Físicos y Virtuales.....	25
Intranet	26
Documentación y Procesos	26
Servicios de Nube (SaaS/PaaS).....	26
Enlaces de Internet (ISPs).....	26
Proveedores de Hosting Web.....	27
Plataformas de Mensajería y Videoconferencia.....	27
APIs de Servicios Financieros	27
Servicios de Soporte Técnico de Fabricantes.....	27
Nube de Respaldo (Cloud Backup).....	27
Gestores de Dominios (DNS)	28
Plataformas de Reclutamiento y Selección	28
Canales de Redes Sociales Corporativas	28
Matriz RACI	28
SECCIÓN 6 - Planificación	31
Activos seleccionados - análisis de amenaza y vulnerabilidad.....	31
Escala de Probabilidad e Impacto.	34
Escala y criterios de interpretación y niveles de riesgo.	34
Cálculo de Riesgo.	35
Matriz de Riesgo.....	37
Mecanismos de Control.	38
SECCIÓN 7 - Soporte.....	41
Justificación Ejecutiva: ¿Qué estamos trabajando y por qué es necesario?.....	41
¿Qué estamos trabajando?.....	41

¿Por qué es necesario?	41
Beneficios para el Negocio (ROI de Seguridad):.....	41
Minuta De Reunión Corporativa.....	42
1. Objetivo de la Sesión	42
Establecer y documentar las directrices de la Cláusula 7 (Soporte) del SGSI, garantizando la asignación de recursos tecnológicos, y estructurando los programas de competencia, concientización y control de información documentada dirigidos específicamente a los operarios, técnicos de mantenimiento y personal de planta.	42
2. Participantes (Comité de Implementación SGSI)	42
3. Invitados clave (Área Operativa y Técnica).....	42
4. Temas Tratados y Acuerdos Formales.....	43
4. Plan de Acción y Responsabilidades.....	43
5. Próxima Reunión de Seguimiento.....	44
7. Cierre y Aprobación.....	44
PRESENTACIÓN.....	46
SECCIÓN 8 - Operación	52
Política seleccionada: Servidores Físicos y Virtuales.....	52
1. Plan (Planear).....	52
Objetivos	52
Riesgos identificados	52
Actividades planificadas	52
Configuraciones de hardening	52
Recursos necesarios	53
Indicadores y métricas	53
Normativas y buenas prácticas relacionadas.....	53
2. Do (Hacer)	54
Acciones realizadas.....	54
Evidencias.....	54
3. Check (Verificar)	54
Actividades de verificación.....	54
Resultados esperados	54
Métricas de evaluación.....	55
4. Act (Actuar)	55
Acciones de mejora.....	55
Mejora continua	55
SECCIÓN 9 - Evaluación del desempeño	56
Objetivo de la Auditoría.....	56
Transcripción de Evidencia:.....	56

I. GESTIÓN DE ACTIVOS INTERNOS.....	56
1. Cédula de Auditoría: Base de Datos	56
2. Cédula de Auditoría: ERP Corporativo (SAP/Oracle).....	57
3. Cédula de Auditoría: Software de Monitoreo de Red.....	58
4. Cédula de Auditoría: Registros de Usuarios y Credenciales.....	59
5. Cédula de Auditoría: Impresoras Empresariales.....	60
6. Cédula de Auditoría: Equipos de Cómputo - Laptops	60
7. Cédula de Auditoría: Herramientas de Administración Remota.....	61
8. Cédula de Auditoría: Servidores Físicos y Virtuales	61
9. Cédula de Auditoría: Intranet.....	62
10. Cédula de Auditoría: Documentación y Procesos.....	63
II. GESTIÓN DE ACTIVOS EXTERNOS	64
11. Cédula de Auditoría: Servicios de Nube (SaaS/PaaS)	64
12. Cédula de Auditoría: Enlaces de Internet (ISPs).....	64
13. Cédula de Auditoría: Proveedores de Hosting Web	65
14. Cédula de Auditoría: Plataformas de Mensajería y Videoconferencia	66
15. Cédula de Auditoría: APIs de Servicios Financieros	67
16. Cédula de Auditoría: Soporte Técnico de Fabricantes.....	67
17. Cédula de Auditoría: Nube de Respaldo (Cloud Backup)	68
18. Cédula de Auditoría: Gestores de Dominios (DNS)	69
19. Cédula de Auditoría: Plataformas de Reclutamiento y Selección.....	69
20. Cédula de Auditoría: Canales de Redes Sociales Corporativas	70
Clasificación de Hallazgos del SGSI	71
Conclusión General.....	71
SECCIÓN 10 - Mejora.....	72
Registro de No Conformidad Mayor (Incidente de Seguridad)	72
Resumen Ejecutivo para la Alta Dirección	72
¿Qué ocurrió?.....	72
¿Cómo ocurrió?.....	72
Activos Críticos Afectados	72
Cuantificación del Impacto (Business Impact)	72
Análisis de Causa Raíz (RCA) e Incumplimiento de Políticas	73
Contexto Técnico (Inteligencia de Amenazas):	73
Plan de Acción Correctiva (CAP) y Contención.....	73
Mejora Continua y Prevención (Actualización del SGSI)	74
Indicadores de Rendimiento del Incidente (KPIs)	74

SECCIÓN 1 - Alcance

Objetivo del alcance

El propósito de este Sistema de Gestión de Seguridad de la Información (SGSI) es establecer los requisitos críticos para la protección de los activos de información gestionados por las direcciones del área de administración y TI.

Este alcance garantiza que el tratamiento de la información de los "Energizadores" cumpla con los pilares de Confidencialidad, Integridad y Disponibilidad, mitigando riesgos asociados al manejo de datos personales sensibles, registros financieros y bases de datos de los activos.

Ámbito de Aplicación (Administración y TI)

La aplicación de los requisitos de esta área se extiende a los siguientes procesos operativos y estratégicos:

- Gestión de Datos Maestros de Activos: Protección de información digital y física, y registros de cumplimiento legal (STPS).
- Gestión Financiera y Contable: Seguridad en el procesamiento de presupuestos, determinación de impuestos, dispersiones bancarias y emisión de CFDI (Timbrado), asegurando que la información financiera sea inalterable y privada.
- Control Documental y Normativo: Resguardo de los manuales de procedimientos, auditorías operativas y certificaciones de industria vinculadas a la calidad (ISO-9001/14001).
- Seguridad Física y Control de Accesos: Protección de los datos derivados de los sistemas de videovigilancia, bitácoras de proveedores y registros biométricos de acceso en las plantas de manufactura.

Acerca de la Empresa

¿Quiénes somos?

Viakon es una marca Viakable, empresa del Grupo Xignux, dedicada a la fabricación y comercialización de conductores eléctricos. Somos una compañía de clase mundial que cuenta con la más avanzada tecnología para la fabricación y pruebas de nuestros productos. Ofrecemos al mercado conductores eléctricos confiables, seguros, eficientes y con una larga vida en servicio.

Viakon es una empresa con más de 70 años de experiencia, más de 5000 productos, 25 sucursales y más de 2000 empleados alrededor del mundo.

Filiales: QUIALITA ALIMENTOS, S de R.L de C.V, Protect Energy, Don Ferm MAgnekon S.A. de C.V.

Contamos con certificaciones ISO-9001 e ISO-14001 en todas las operaciones, lo que avala nuestra calidad de clase mundial.

Un poco de nuestra historia.

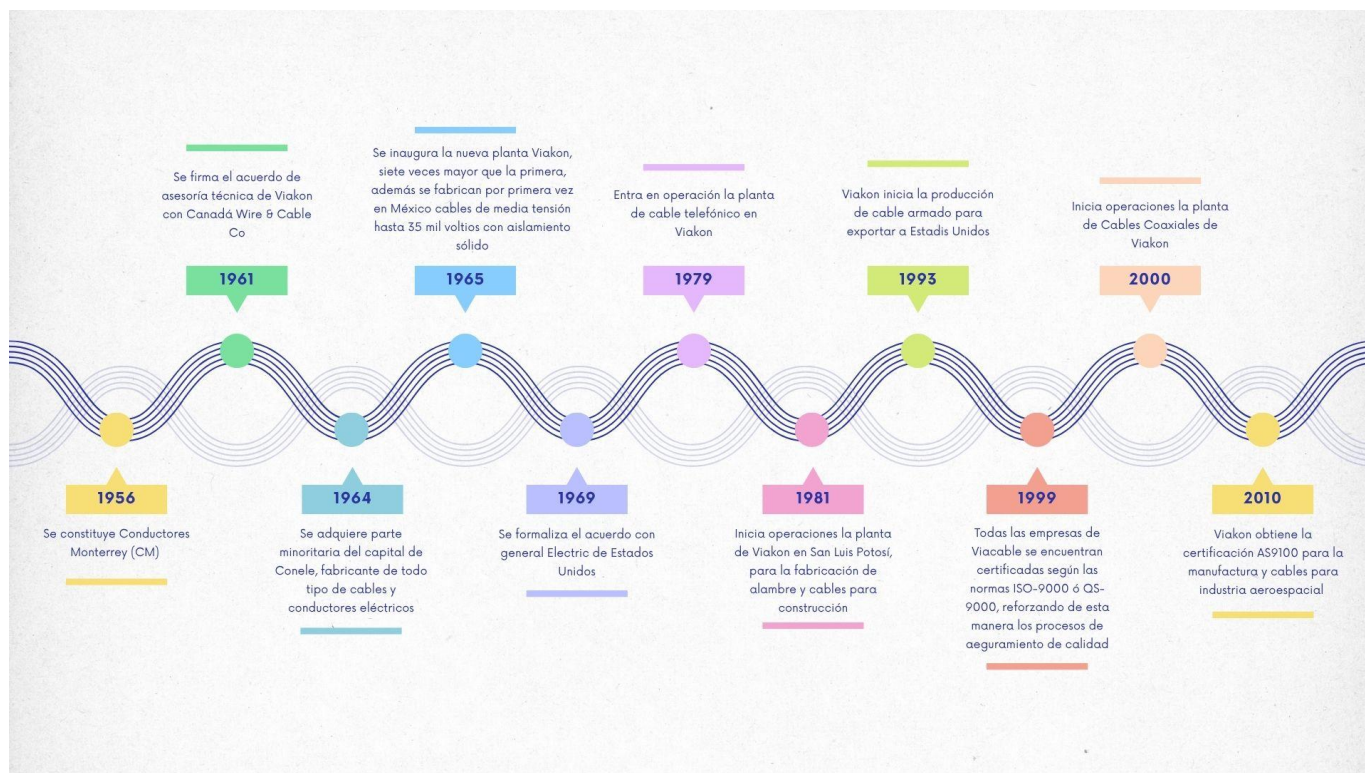


ILUSTRACIÓN 1 HISTORIA DE LA EMPRESA

Sitio web.

<https://viakon.com>

Misión

“Transmitir energía que activa tu vida”.

Visión

Ser la empresa preferida del mercado de transmisión de energía, duplicando nuestro valor y ofreciendo la mejor experiencia para nuestros clientes.

- Tener el mejor equipo de energizadores con enfoque humano y congruente con nuestros valores.
- Ser reconocidos por innovaciones relevantes.
- Asegurar la excelencia en la cadena.
- Ser modelo en el desarrollo de iniciativas sostenibles que contribuyan a la construcción de un mejor futuro.

Objetivos Organizacionales.

Ética y Valores

Viakable se distingue por ser una empresa íntegra con estrictos principios éticos. Sus relaciones, negocios y operaciones están basados en su código de ética y valores, esto ha logrado que los colaboradores, clientes, socios proveedores y la comunidad a su alrededor continúen depositando su total confianza en nosotros. Siempre comprometidos a actuar con apego a las leyes y los principios éticos y morales con absoluta transparencia y hablando con la verdad.

Planeta

Una parte esencial de nuestra operación es la adecuada gestión de los recursos que utilizamos para producir de forma eficiente, por lo que continuamente estamos analizando e integrando iniciativas de mejora en nuestros procesos críticos y relevantes con la finalidad de mitigar el impacto ambiental de nuestras operaciones y reducir costos. Dentro de los insumos más relevantes se encuentran: consumos de agua, energía y materiales, al igual que las emisiones y residuos. Un aspecto fundamental para reforzar el aprovechamiento eficiente de los recursos en Viakable es trabajar durante todo el año en la cultura de responsabilidad ambiental con nuestros colaboradores a través de campañas de concientización, talleres, eventos y actividades.

Nuestra gente

El activo más importante para el éxito de cada uno de nuestros negocios es nuestro capital humano, por esta razón mantenemos espacios de trabajo dignos, respetuosos, colaborativos y de comunicación constante en todos los lugares donde tenemos operaciones. Tenemos el compromiso de fomentar un ambiente abierto e incluyente, en el que cada colaborador se sienta altamente motivado, productivo y comprometido para impulsar su éxito personal y de la empresa, por medio de una ejecución superior, buscando siempre la mejora continua y la innovación.

Comunidad

Somos una empresa que busca transformar las comunidades en las que operamos, generando relaciones de ganar-ganar mediante Iniciativas Sociales, en las que participamos voluntariamente en conjunto con organizaciones de la sociedad civil. Hemos asumido también el compromiso de invertir tiempo, experiencia, conocimiento y recursos en diversas iniciativas que inciden en el mejoramiento de las condiciones de vida y desarrollo de las comunidades en las que operamos, siendo dichas iniciativas relevantes tanto para la sustentabilidad de quienes nos rodean como para nuestra organización.

Reconocimientos y Certificaciones

Nuestro Círculo de Calidad, así como la perseverancia y constancia de nuestras participaciones como empresa, ha sido distinguida por la AMTE (Asociación Mexicana de Trabajo en Equipo A.C.), promotora de la cultura de calidad y trabajo en equipo para la Mejora Continua en México.

Además, Viakon ha sido reconocido en cuestión de investigación y desarrollo tecnológico de nuevos productos, materiales o procesos por el CONACYT.

El reconocimiento Cultura Tecnológica Empresarial se ha otorgado a tan solo 69 empresas desde 2001 por sus actividades de investigación y desarrollo.

La cultura de trabajo en Viakon también es reconocida. Clientes como Montoi y Soriana nos han distinguido en más de una ocasión como Proveedor Confiable.

Premio Dr. Mitsunori Nakano a la Perseverancia en el 2004

Viakon fue reconocido por haber logrado en 10 ocasiones la participación de sus equipos como finalistas de los Concursos Nacionales de Equipo de Trabajo. El premio lleva el nombre del Dr. Mitsunori Nakano, un experto y entusiasta promotor, patrocinador e impulsor de estos Concursos.

Certificados

Desde sus inicios, Viakon ha sostenido invariablemente su voluntad de mantenerse como pionero y líder de la industria.

Como compañía de clase mundial, Viakon cuenta con la más avanzada tecnología para la fabricación y pruebas de sus productos, lo cual le permite ofrecer al mercado conductores eléctricos confiables, seguros, eficientes y con una larga vida en servicio. A nivel nacional e internacional, los productos de viakon cuentan con la certificación de los organismos más prestigiados del mundo ya que son capaces de satisfacer las especificaciones más exigentes.

Entre estos certificados se encuentra:

- ABS
- ANCE
- cesmec
- CFE
- PEMEX
- PROFEPA

Política de Calidad Viakon

Mejora continua para satisfacer y exceder los requerimientos de los clientes externos e internos.

Políticas Xignux

- Entendimiento profundo de sus conceptos, métodos y prácticas.
- Mejorar nuestras operaciones orientados a satisfacer a nuestros clientes y ser la mejor opción reconocida por ellos.
- Acrecentar sustentablemente el crecimiento y la rentabilidad en nuestras empresas.

Política de Calidad, Ambiental, Salud y Seguridad

En Viakon, empresa dedicada a la manufactura de conductores eléctricos, estamos comprometidos en proporcionar productos y servicios que satisfagan los requerimientos de nuestros clientes y de nuestras partes interesadas, generando acciones para eficientizar nuestros recursos, proteger el medio ambiente, prevenir y reducir la contaminación, los riesgos laborales, la eliminación de peligros y la prevención de enfermedades laborales, estableciendo condiciones de trabajo seguras, saludables y libre de lesiones que deterioren la salud de nuestros Energizadores, tomando en cuenta la consulta y participación de trabajadores y representantes, cumpliendo con la normatividad aplicable, respetando los valores establecidos por la organización, a través de la mejora continua de nuestros Sistemas de Gestión, de nuestros procesos y de nuestro Sistema Operativo CTX.

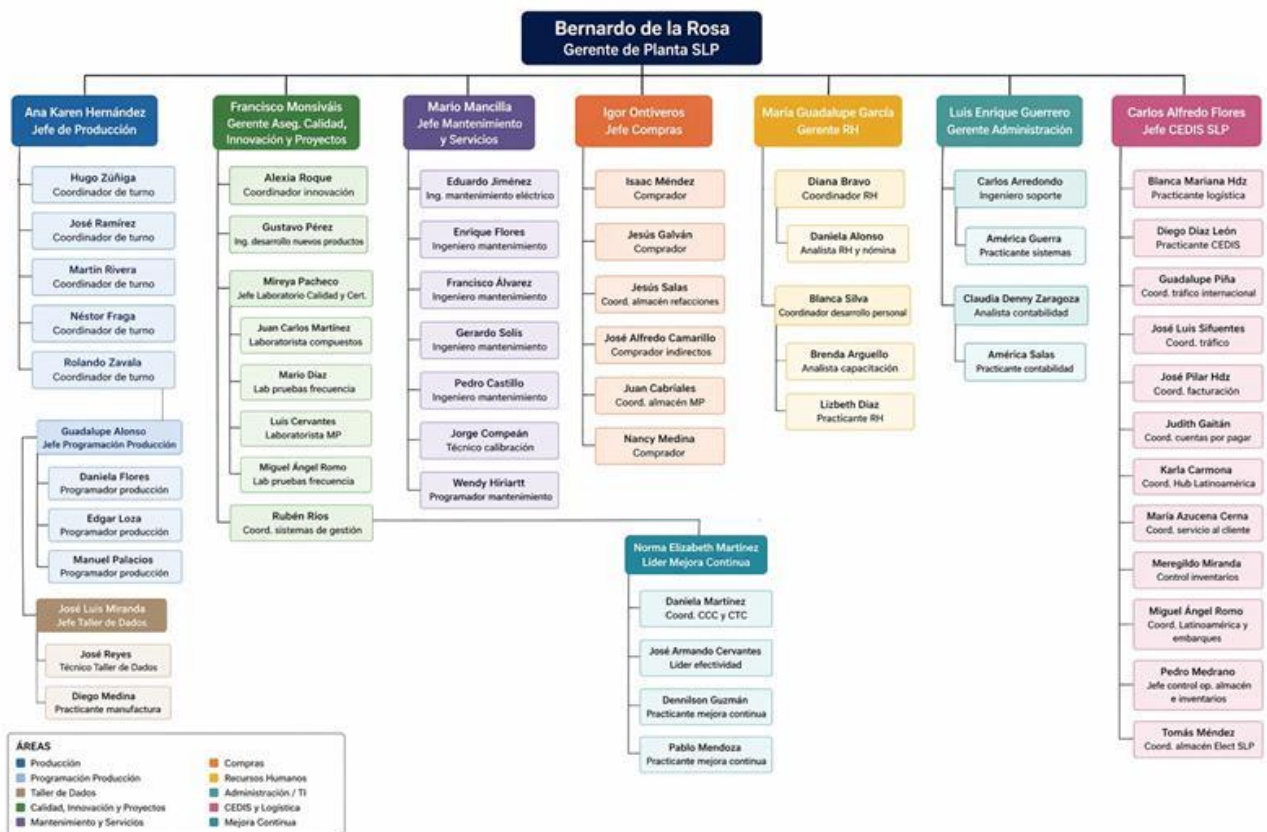


ILUSTRACIÓN 2 ORGANIGRAMA D

Estructura General del Organigrama.

El organigrama corresponde a la estructura organizacional de una planta en San Luis Potosí (SLP), encabezada por Bernardo de la Rosa (Gerente de Planta SLP).

La organización se divide en 7 líneas de reporte directo (gerencias y jefaturas), las cuales se subdividen en 10 áreas funcionales según la nomenclatura de colores:

- Producción, Programación de Producción y Taller de Datos: Dirigido por Ana Karen Hernández (jefe de Producción).
- Calidad, Innovación y Proyectos: Dirigido por Francisco Monsiváis (Gerente Aseg. Calidad, Innovación y Proyectos).
- Mantenimiento y Servicios: Dirigido por Mario Mancilla (jefe Mantenimiento y Servicios).
- Compras: Dirigido por Igor Ontiveros (jefe Compras).
- Recursos Humanos: Dirigido por María Guadalupe García (Gerente RH).
- Administración / TI: Dirigido por Luis Enrique Guerrero (Gerente Administración).
- CEDIS y Logística: Dirigido por Carlos Alfredo Flores (jefe CEDIS SLP).
- Mejora Continua: Línea a cargo de Norma Elizabeth Martínez, la cual muestra una conexión matricial o de soporte que se desprende de la estructura de sistemas de gestión.

Área de Administración / TI

Esta área está bajo la dirección de Luis Enrique Guerrero (Gerente Administración). El departamento unifica dos funciones críticas para la planta: el soporte tecnológico (Sistemas) y la gestión financiera interna (Contabilidad).

Su estructura es plana y cuenta con cuatro reportes directos, organizados en dos parejas de analista/ingeniero y practicante:

1. Subárea de Tecnologías de la Información (TI)

Encargada del soporte técnico y el mantenimiento de los sistemas de la planta.

Carlos Arredondo: Ingeniero soporte.

América Guerra: Practicante sistemas.

2. Subárea de Contabilidad

Encargada del control financiero y contable local.

Claudia Denny Zaragoza: Analista contabilidad.

América Salas: Practicante contabilidad.

SECCIÓN 2 - Referencias Normativas

En esta sección se establece el marco normativo internacional aplicable al Sistema de Gestión de Seguridad de la Información (SGSI) implementado para la Dirección de Administración y Tecnologías de la Información (TI) de Viakon. Las referencias aquí citadas constituyen la columna vertebral metodológica para proteger los procesos transaccionales del ERP Corporativo (SAP/Oracle), la infraestructura de red, y las bases de datos que albergan la propiedad intelectual y los datos personales de los "Energizadores".

Para las referencias fechadas, únicamente es aplicable la edición citada. Para referencias no fechadas, se aplicará la última edición vigente, incluyendo enmiendas y actualizaciones emitidas por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC).

2.1 Norma Base del SGSI

ISO/IEC 27001:2022 — Sistemas de Gestión de Seguridad de la Información — Requisitos. Constituye el estándar base y certificable del presente proyecto. En lugar de ofrecer metodologías rígidas, esta norma dicta los requisitos indispensables para establecer, implementar, mantener y mejorar continuamente el SGSI.

- **Aplicación en Viakon:** Se utiliza como la hoja de ruta directiva para estructurar las políticas de TI, definir el alcance (Cláusula 4), comprometer a la Alta Dirección (Cláusula 5) y establecer las métricas de evaluación de desempeño que protegen el flujo de las operaciones de manufactura y administración financiera.

2.2 Familia ISO/IEC 27000: Controles y Gestión de Riesgos

Para dar cumplimiento a los requisitos exigidos por la norma base, el SGSI de Viakon se apoya metodológicamente en las siguientes normas para la mitigación de vulnerabilidades y el tratamiento del riesgo:

- **ISO/IEC 27002:2022 — Controles de seguridad de la información.**
Esta norma funciona como el catálogo de buenas prácticas y directrices para implementar las medidas de seguridad exigidas en el Anexo A de ISO 27001.
 - **Aplicación en Viakon:** Guía la configuración técnica de nuestros activos. Por ejemplo, se utiliza para dictaminar las reglas de complejidad de contraseñas, la habilitación de Autenticación Multifactorial (MFA) en el Directorio Activo, y la segmentación de nuestras VLANs corporativas para evitar accesos no autorizados al ERP.
- **ISO/IEC 27005:2022 — Gestión del riesgo de seguridad de la información.**
Establece las directrices para la identificación, análisis, evaluación y tratamiento de los riesgos cibernéticos, traduciendo amenazas técnicas en impacto de negocio.
 - **Aplicación en Viakon:** Es la metodología utilizada por el Comité de Seguridad para calcular el impacto financiero y operativo ante la posibilidad de un ataque de Ransomware o el secuestro de sesión, determinando qué riesgos son aceptables y cuáles exigen presupuesto inmediato para remediación.

2.3 Normas Complementarias

Dado el entorno híbrido de TI y la naturaleza de los datos procesados en la organización, el SGSI integra lineamientos de las siguientes normas especializadas de la familia ISO/IEC 27000:

- **ISO/IEC 27000:2018 — Visión general y vocabulario.**
 - Aplicación en Viakon: Estandariza la terminología corporativa. Asegura que tanto la Alta Dirección (Grupo Xignux) como los operarios entiendan bajo el mismo rigor técnico conceptos como "Disponibilidad", "Confidencialidad", "Amenaza" o "Vulnerabilidad".
- **ISO/IEC 27017:2015 — Controles de seguridad para servicios en la nube.**
 - Aplicación en Viakon: Ante la integración de nuestros repositorios y sistemas SaaS/PaaS, esta norma nos dicta las responsabilidades compartidas con nuestros proveedores de nube, asegurando que la información financiera y operativa fuera del Data Center (DCN Tower) esté cifrada y protegida.
- **ISO/IEC 27701:2019 — Extensión para la gestión de la privacidad de la información.**
 - Aplicación en Viakon: Esencial para el cumplimiento legal. TI administra bases de datos con Identidad Personal (PII) de más de 2,000 Energizadores. Esta norma nos permite establecer controles para prevenir brechas de privacidad y cumplir con la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), mitigando el riesgo de multas ante el INAI.
- **ISO/IEC 27035-1:2023 — Gestión de incidentes de seguridad de la información.**
 - Aplicación en Viakon: Define las fases de preparación, detección, respuesta y aprendizaje post-incidente. Fue la base normativa utilizada por nuestro Equipo de Respuesta a Incidentes (CSIRT) para contener recientes amenazas de intrusión e implementar acciones de mejora continua.

2.4 Referencias Bibliográficas

- Organización Internacional de Normalización. (2018). Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de seguridad de la información - Visión general y vocabulario (ISO/IEC 27000:2018). <https://www.iso.org/standard/73906.html>
- Organización Internacional de Normalización. (2022). Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de la seguridad de la información — Requisitos (ISO/IEC 27001:2022). <https://www.iso.org/standard/82875.html>
- Organización Internacional de Normalización. (2022). Seguridad de la información, ciberseguridad y protección de la privacidad — Controles de seguridad de la información (ISO/IEC 27002:2022). <https://www.iso.org/standard/75652.html>
- Organización Internacional de Normalización. (2022). Seguridad de la información, ciberseguridad y protección de la privacidad — Gestión de riesgos de seguridad de la información (ISO/IEC 27005:2022). <https://www.iso.org/standard/80585.html>

SECCIÓN 3 - Términos y Condiciones

Para fines de la presente implementación en Viakon, los siguientes términos fundamentales se agrupan por su función dentro del ciclo de vida del Sistema de Gestión de Seguridad de la Información (SGSI).

1. Aceptación del riesgo (Risk acceptance)

Decisión informada de asumir un riesgo concreto [Fuente: Guía ISO 73: 2009].

2. Activo (Asset)

Cualquier información o elemento relacionado con el tratamiento de la misma (sistemas, soportes, edificios, personas) que tenga valor para la organización y requiera protección.

3. Alta dirección (Top management)

Persona o grupo de personas que dirige y controla una organización al más alto nivel, con autoridad para proporcionar recursos y delegar responsabilidades (ej. CEO, CFO, CIO).

4. Amenaza (Threat)

Causa potencial de un incidente no deseado, que puede provocar daños a un sistema o a la organización.

5. Análisis de riesgos (Risk analysis)

Proceso sistemático para comprender la naturaleza del riesgo y determinar su nivel [Fuente: Guía ISO 73: 2009].

6. Análisis de riesgos cualitativo (Qualitative risk analysis)

Análisis basado en escalas de valoración para determinar la gravedad del impacto y la probabilidad.

7. Análisis de riesgos cuantitativo (Quantitative risk analysis)

Análisis basado en la estimación de pérdidas financieras causadas por el impacto.

8. Ataque (Attack)

Intento de destruir, exponer, alterar, deshabilitar, robar u obtener acceso no autorizado a un activo.

9. Auditoría (Audit)

Proceso de verificación independiente sobre el cumplimiento de requisitos determinados.

10. Auditor (Auditor)

Persona encargada de realizar la auditoría.

11. CID (CIA)

Acronimo de Confidencialidad, Integridad y Disponibilidad; dimensiones básicas de la seguridad de la información.

12. Comunicación y consulta de riesgos (Risk communication and consultation)

Procesos iterativos para compartir información y entablar un diálogo con las partes interesadas sobre la gestión del riesgo.

13. Confidencialidad (Confidentiality)

Propiedad de la información de no ponerse a disposición o ser revelada a individuos, entidades o procesos no autorizados.

14. Control (Control)

Medida o conjunto de medidas que modifican el riesgo. Los controles incluyen procesos, políticas, dispositivos, prácticas u otras acciones que aseguran el cumplimiento de los objetivos de seguridad.

15. Control de acceso (Access control)

Garantizar que el acceso a los activos esté autorizado y restringido según los requisitos comerciales y de seguridad.

16. Disponibilidad (Availability)

Propiedad de la información de estar accesible y utilizable cuando lo requiera una entidad autorizada.

17. Estimación de riesgos (Risk evaluation)

Proceso de comparar los resultados del análisis de riesgos con los criterios de riesgo para determinar si son aceptables [Fuente: ISO Guide 73:2009].

18. Evaluación de riesgos (Risk assessment)

Proceso global de identificación, análisis y estimación de riesgos.

19. Evento (Event)

Ocurrencia o cambio de un conjunto particular de circunstancias.

20. Evento de seguridad de la información (Information security event)

Ocurrencia identificada que indica una posible violación de la política de seguridad o falla de controles.

21. Gestión de incidentes de seguridad de la información (Information security incident management)

Procesos para detectar, reportar, evaluar, responder, tratar y aprender de los incidentes de seguridad.

22. Gestión de riesgos (Risk management)

Actividades coordinadas para dirigir y controlar una organización con respecto al riesgo [Fuente: ISO Guide 73:2009].

23. Identificación de riesgos (Risk identification)

Proceso de encontrar, reconocer y describir riesgos [Fuente: Guía ISO 73:2009].

24. Impacto (Impact)

Coste para la empresa de un incidente, que puede ser financiero, reputacional o legal.

25. Incidente (Incident)

Evento único o serie de eventos de seguridad de la información que tienen una probabilidad significativa de comprometer las operaciones del negocio y amenazar la seguridad de la información.

26. Incidente de seguridad de la información (Information security incident)

Evento único o serie de eventos inesperados que poseen una probabilidad significativa de comprometer las operaciones del negocio y amenazar la seguridad de la información.

27. Indicador (Indicator)

Medida que proporciona una estimación o evaluación.

28. Información documentada (Documented information)

Información requerida para ser controlada y mantenida por la organización, en cualquier formato, medio o fuente.

29. Integridad (Integrity)

Propiedad de la información relativa a su exactitud y completitud.

30. Inventario de activos (Assets inventory)

Lista de recursos dentro del alcance del SGSI que tienen valor para la organización y requieren protección.

31. ISO/IEC 27001

Norma internacional que establece los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI).

32. Nivel de riesgo (Level of risk)

Magnitud de un riesgo expresada como combinación de consecuencias y probabilidad [Fuente: ISO Guide 73:2009].

33. Objetivo (Objective)

Resultado a alcanzar, ya sea estratégico, táctico u operativo.

34. Organización (Organization)

Persona o grupo de personas con funciones, responsabilidades y autoridades propias para lograr sus objetivos.

35. Plan de continuidad del negocio (Business Continuity Plan)

Estrategia orientada a permitir la continuación de las funciones críticas ante eventos imprevistos.

36. Plan de tratamiento de riesgos (Risk treatment plan)

Documento que define las acciones para gestionar riesgos inaceptables e implantar controles de protección.

37. Rendimiento (Performance)

Resultado medible, que puede relacionarse con actividades, procesos o sistemas.

38. Riesgo (Risk)

Efecto de la incertidumbre sobre los objetivos, manifestado como una desviación positiva o negativa de lo esperado.

39. Sarbanes-Oxley (SOX)

Ley estadounidense que establece normas para auditores y obliga a empresas públicas a garantizar la seguridad de la información financiera.

40. Seguridad de la información (Information security)

Preservación de la confidencialidad, integridad y disponibilidad de la información.

41. Sistema de Información (Information system)

Conjunto de aplicaciones, servicios, activos de TI u otros componentes que manejan información.

42. Sistema de Gestión de Seguridad de la Información (SGSI / ISMS)

Sistema de gestión para establecer, implementar, mantener y mejorar la seguridad de la información.

43. Tratamiento de riesgos (Risk treatment)

Proceso para modificar el riesgo, ya sea evitándolo, compartiéndolo, reteniéndolo o eliminando su fuente [Fuente: Guía ISO 73:2009].

44. Tratamiento del riesgo

Proceso para seleccionar e implementar medidas destinadas a modificar el riesgo, tales como evitarlo, transferirlo, mitigarlo o aceptarlo.

45. Vulnerabilidad (Vulnerability)

Debilidad de un activo o control que puede ser explotada por una o varias amenazas, comprometiendo la seguridad de la información de los departamentos de Administración y TI.

Condiciones de la Intervención (Acuerdo Operativo y Alcance)

Para garantizar la transparencia, legalidad y el nulo impacto a las operaciones críticas de Viakon durante la implementación y auditoría del SGSI, se establecen las siguientes condiciones de intervención:

Confidencialidad y Manejo de Evidencias

Toda la información recabada durante la auditoría (logs de red, configuraciones del ERP SAP/Oracle, arquitecturas de Active Directory y datos personales de los Energizadores) está sujeta a un estricto Acuerdo de Confidencialidad (NDA).

- **Manejo de Evidencias:** Las capturas de pantalla, bases de datos exportadas y hallazgos técnicos se almacenarán exclusivamente en discos duros cifrados (AES-256) propiedad del equipo auditor.
- **Destrucción de Datos:** Una vez emitido el dictamen final del SGSI, las evidencias técnicas y datos sensibles serán sanitizados y destruidos mediante borrado seguro, reteniendo únicamente los reportes ejecutivos.

Límites de Actuación y Exclusiones Técnicas

- **Límites Operativos:** Las pruebas de evaluación de vulnerabilidades, escaneos de red o pruebas de penetración (Pentesting) se ejecutarán **únicamente en ventanas de mantenimiento autorizadas** (fines de semana o madrugadas) para evitar interrupciones en el sistema financiero o de manufactura.
- **Exclusiones:** Queda estrictamente prohibida la interacción directa, alteración o escaneo de las redes de Tecnología Operativa (OT/SCADA) de Nivel 0 y 1 en las plantas de extrusión, al encontrarse fuera del alcance definido de TI corporativa y representar un riesgo para la seguridad física industrial.

Supuestos y Restricciones

- **Supuestos:** La intervención se basa en el supuesto de que la Alta Dirección de Viakon proveerá acceso irrestricto a la Información Documentada (políticas previas, inventarios de activos y diagramas de red) en los tiempos acordados.
- **Restricciones:** El equipo auditor no realizará modificaciones en los sistemas de producción (ERP) ni alterará los permisos de la Subdirección de Finanzas y RRHH sin la presencia y autorización de los dueños de dichos procesos.

Matriz de Responsabilidades

- **Responsabilidad del Equipo Implementador/Auditor (Líder SGSI):** Identificar brechas normativas, diseñar controles bajo el estándar ISO/IEC 27001:2022, elaborar los reportes de No Conformidad y proponer los Planes de Acción Correctiva (CAP).
- **Responsabilidad de Viakon (Subdirección de TI y Alta Dirección):** Suministrar información verídica, disponer del personal para entrevistas y asignar los presupuestos técnicos para la remediación de los hallazgos reportados.



SECCIÓN 4 - Contexto de la organización

Código	Activo de Información (Nombre Original)	Propietario / Ubicación	Proceso Asociado	Responsable Operativo	Dependencia Tecnológica	Clasificación CID
ACT-INT-01	Bases de datos	Gerente de TI / CPD principal	Gestión de datos críticos	Administrador de BD	Servidores, SAN (ej. SQL Server)	C: Alta: AltaD: Alta
ACT-INT-02	Programa de capacitación (herramientas y rutas)	Gerente de RRHH / LMS interno	Capacitación continua	Coordinador de capacitación	Plataforma e-learning, Intranet	C: Medial: MediaD: Media
ACT-INT-03	Software de monitoreo de red y servidores	Gerente de Seguridad TI / Consola central NOC	Monitoreo de infraestructura	Analista de monitoreo	Servidores, switches, firewalls	C: Medial: AltaD: Alta
ACT-INT-04	Registros de usuarios y credenciales	Gerente de Seguridad TI / Directorio activo / SIAM	Control de acceso	Administrador de identidades	Servidores de dominio, MFA	C: Alta: AltaD: Alta
ACT-INT-05	Impresoras empresariales	Gerente de Operaciones / Oficinas y planta	Impresión de documentos	Soporte TI	Red LAN, suministro eléctrico	C: Medial: MediaD: Media
ACT-INT-06	Equipos de cómputo	Gerente de TI / Estaciones de trabajo	Operaciones diarias	Usuario final / Soporte TI	Red, servidores, antivirus	C: Medial: MediaD: Media
ACT-INT-07	Herramientas de administración remota	Gerente de Seguridad TI / Servidor de gestión	Soporte remoto	Administrador de sistemas	VPN, firewalls, autenticación	C: Alta: AltaD: Alta
ACT-INT-08	Servidores físicos y virtuales	Gerente de TI / CPD / Hipervisor	Procesamiento central	Arquitecto de sistemas	SAN, switches, UPS, HVAC	C: Alta: AltaD: Alta
ACT-INT-09	Intranet	Gerente de Comunicaciones / Portal interno	Comunicación interna	Webmaster	Servidores web, DNS interno	C: Medial: MediaD: Media
ACT-INT-10	ERPs corporativos	Gerente de TI / CPD / Nube	Gestión integral del negocio	Líder funcional ERP	Servidores, BD, red, backup	C: Alta: AltaD: Alta
ACT-INT-11	Documentación y procesos	Gerente de Calidad / Repositorio documental	Gestión de la calidad	Documentador	Intranet, control de versiones	C: Medial: AltaD: Media
ACT-INT-12	Firewalls y dispositivos de seguridad perimetral	Gerente de Seguridad TI / Perímetro de red	Seguridad perimetral	Ingeniero de seguridad	ISP, switches de core	C: Alta: AltaD: Alta
ACT-INT-13	Sistemas de respaldo y recuperación (Backup)	Gerente de TI / CPD + nube	Respaldo y DRP	Administrador de backup	Almacenamiento, red, software	C: Alta: AltaD: Alta
ACT-INT-14	Conmutadores (Switches) y puntos de acceso Wi-Fi	Gerente de TI / Racks y áreas comunes	Conectividad LAN/WLAN	Ingeniero de redes	Fibra óptica, cableado, PoE	C: Medial: AltaD: Alta
ACT-INT-15	Software antivirus y EDR (Endpoint Detection and Response)	Gerente de Seguridad TI / Todos los endpoints	Protección de endpoints	Analista de ciberseguridad	Consola central, servidor act.	C: Medial: AltaD: Media
ACT-INT-16	Certificados digitales y llaves criptográficas	Gerente de Seguridad TI / HSM / Repositorio seguro	Cifrado y autenticación	Criptógrafo	Servidores, PKI, HSM	C: Alta: AltaD: Media

ACT-INT-17	Consolas de gestión de parches y actualizaciones	Gerente de TI / Servidor de administración	Actualización de software	Ingeniero de sistemas	Repositorio WSUS/SCCM, red	C: Medial: MediaD: Media
ACT-INT-18	Sistemas de almacenamiento masivo (SAN/NAS)	Gerente de TI / CPD	Almacenamiento compartido	Administrador de almacenamiento	Fibre Channel, switches, HDD/SSD	C: Alta: AltaD: Alta
ACT-INT-19	Repositorios de scripts y código fuente	Gerente de Desarrollo / Git / Servidor interno	Automatización y desarrollo	Líder de desarrollo	Servidores, control de versiones	C: Alta: AltaD: Media
ACT-INT-20	Plan de Continuidad del Negocio y Recuperación de Desastres (BCP/DRP)	Gerente de Riesgos / Portal de gobierno	Respuesta a emergencias	Comité de crisis	Almacenamiento ext., comunicaciones	C: Alta: AltaD: Alta

Activos Externos

Código	Activo de Información (Nombre Original)	Propietario / Ubicación	Proceso Asociado	Responsable Operativo	Dependencia Tecnológica	Clasificación CID
ACT-EXT-01	Servicios de Nube (SaaS/PaaS)	Gerente de TI / Nube (Azure / AWS)	Productividad y colaboración	Arquitecto de nube	Internet, API, SSO	C: Alta: AltaD: Media
ACT-EXT-02	Enlaces de Internet (ISPs)	Gerente de TI / Infraestructura del ISP	Conectividad WAN	Ingeniero de redes	Routers, fibra óptica, módems	C: Medial: AltaD: Alta
ACT-EXT-03	Proveedores de Hosting Web	Gerente de Marketing / Datacenter del proveedor	Presencia digital	Webmaster	DNS, CDN, servidores web	C: Medial: MediaD: Media
ACT-EXT-04	Enlaces de Comunicación Dedicados	Gerente de TI / Red MPLS / fibra dedicada	Comunicación inter-sedes	Ingeniero de redes	Routers, switches, VLAN	C: Medial: AltaD: Alta
ACT-EXT-05	Plataformas de Mensajería y Videoconferencia	Gerente de Comunicaciones / Nube del proveedor	Comunicación remota	Admin. de colaboración	Internet, micrófonos, cámaras	C: Medial: MediaD: Media
ACT-EXT-06	APIs de Servicios Financieros	Gerente de Finanzas / Servidores del banco / SAT	Facturación y pagos	Tesorero	Internet, certificados, tokens	C: Alta: AltaD: Alta
ACT-EXT-07	Servicios de Soporte Técnico de Fabricantes	Gerente de TI / Centro de soporte del fabricante	Mantenimiento de hardware	Administrador de activos	Contrato de soporte, acceso remoto	C: Medial: MediaD: Media
ACT-EXT-08	Nube de Respaldo (Cloud Backup)	Gerente de TI / Nube (proveedor de backup)	Respaldo y DRP	Administrador de backup	Internet, API, ancho de banda	C: Alta: AltaD: Alta

ACT-EXT-09	Herramientas de Diseño y Prototipado en la Nube	Gerente de Marketing / Nube del proveedor	Diseño gráfico y UX	Diseñador senior	Internet, navegador, GPU remota	C: Medial: MediaD: Media
ACT-EXT-10	Proveedores de Ciberinteligencia	Gerente de Seguridad TI / Plataforma del proveedor	Monitoreo de amenazas	Analista de ciberseguridad	Internet, API, SIEM	C: Medial: AltaD: Media
ACT-EXT-11	Gestores de Dominios (DNS)	Gerente de TI / Plataforma DNS	Resolución de nombres	Ingeniero de redes	Internet, registros DNS, SSL	C: Medial: AltaD: Alta
ACT-EXT-12	Bases de Datos de Normativas Externas	Gerente de Calidad / Portales gubernamentales	Cumplimiento normativo	Auditor de calidad	Internet, navegador, credenciales	C: Medial: MediaD: Media
ACT-EXT-13	Plataformas de Reclutamiento y Selección	Gerente de RRHH / Nube del proveedor	Reclutamiento y selección	Reclutador	Internet, correo electrónico	C: Medial: MediaD: Media
ACT-EXT-14	Sistemas de Monitoreo de Logística (GPS)	Gerente de Logística / Nube del proveedor GPS	Distribución y entregas	Coordinador de logística	Internet, GPS, red celular	C: Medial: MediaD: Alta
ACT-EXT-15	Servicios de Auditoría de Ciberseguridad Externos	Gerente de Seguridad TI / Oficinas de la consultora	Auditoría y cumplimiento	Auditor externo / Hacker	Acceso remoto, NDA, pentesting	C: Alta: AltaD: Media
ACT-EXT-16	Nodos de Distribución de Contenido (CDN)	Gerente de TI / Red global CDN	Entrega de contenido	Ingeniero de redes	DNS, servidores web, caché	C: Medial: MediaD: Alta
ACT-EXT-17	Sistemas de Verificación de Identidad de Terceros	Gerente de Seguridad TI / Nube del proveedor MFA	Control de acceso	Administrador de identidades	Internet, App MFA, SSO	C: Alta: AltaD: Alta
ACT-EXT-18	Plataformas de Capacitación Externa (E-learning)	Gerente de RRHH / Nube del proveedor	Capacitación continua	Coordinador de capacitación	Internet, LMS, navegador	C: Medial: MediaD: Media
ACT-EXT-19	Infraestructura de Centros de Datos de Terceros	Gerente de TI / Datacenter del proveedor	Alojamiento de servidores	Arq. de infraestructura	Enlace, UPS, HVAC, seguridad física	C: Alta: AltaD: Alta
ACT-EXT-20	Canales de Redes Sociales Corporativas	Gerente de Marketing / Plataformas sociales	Marketing y comunicación	Community manager	Internet, credenciales, gestor R.S.	C: Medial: MediaD: Media

SECCIÓN 5 - Liderazgo

Política General de la Organización

Objetivo

Establecer el marco de referencia para la protección de los activos de información de Viakon, garantizando la Confidencialidad (que solo los autorizados accedan), Integridad (que la información no sea alterada) y Disponibilidad (que esté lista cuando se necesite). Se busca mitigar riesgos ante amenazas internas y externas, asegurar el cumplimiento legal (como la Ley de Protección de Datos) y consolidar la seguridad como un valor cultural en la organización para el cumplimiento de sus objetivos estratégicos.

Alcance de Aplicabilidad

Esta política es de cumplimiento obligatorio para todo el personal interno, prestadores de servicios, proveedores y socios comerciales. El alcance técnico comprende la totalidad del ecosistema de información: desde la infraestructura física (servidores, oficinas) hasta los activos lógicos (bases de datos, software, nube).

Compromiso de la Dirección

La Alta Dirección asume la responsabilidad de liderar el SGSI mediante:

- La provisión incondicional de los recursos financieros y el capital humano especializado necesarios para la operación y mejora continua del sistema.
- La revisión ejecutiva periódica del SGSI para asegurar su alineación dinámica con la Matriz de Riesgos y los objetivos estratégicos corporativos.
- La promoción y exigencia de una cultura de "Cero Confianza" (Zero Trust) y "Privilegios Mínimos" en todas las capas de la organización.

Políticas Funcionales

Internos

Base de Datos

- **Estándar:** Es estrictamente obligatorio implementar cifrado a nivel de columna (TDE) para datos PII (Identidad Personal) y requerir Autenticación Multifactor (MFA) para todo acceso con roles de sysadmin o db_owner.
- **Directriz:** Se recomienda la habilitación del Enmascaramiento Dinámico de Datos (DDM) en entornos de pre-producción para evitar la exposición de datos reales durante pruebas de desarrollo.
- **Procedimiento:** El escalamiento temporal de privilegios se ejecutará mediante la creación de un ticket en el sistema ITSM, el cual requerirá autorización digital previa del Dueño de la Información (Data Owner) antes de que el administrador de TI otorgue el acceso de escritura.

- **Línea base:** Configuración de respaldos incrementales automatizados cada 4 horas y rotación criptográfica de las claves de servicio cada 90 días naturales.

ERP Corporativo - SAP/Oracle

- **Estándar:** El acceso remoto o externo al ERP corporativo queda estrictamente restringido y solo es permitido a través de túneles VPN IPsec combinados con MFA.
- **Directriz:** Se aconseja ejecutar un análisis trimestral mediante módulos GRC (Governance, Risk, and Compliance) para detectar conflictos de Segregación de Funciones (SoD) en el departamento de Finanzas.
- **Procedimiento:** Todo alta de usuario en el ERP requerirá el llenado del formulario JML (Joiner, Mover, Leaver) con firma autógrafa o digital del Gerente de Área y validación final por el Oficial de Seguridad (CISO).
- **Línea base:** Cierre forzado de sesiones TCP/UDP inactivas tras 15 minutos y políticas de contraseñas de al menos 12 caracteres.

Software de Monitoreo de Red

- **Estándar:** Es obligatorio restringir el acceso a las consolas del NOC mediante lista blanca de IPs corporativas y Autenticación Multifactor (MFA).
- **Directriz:** Ejecutar auditorías trimestrales sobre los cambios en los umbrales de alerta y baselines de comportamiento de red.
- **Procedimiento:** Para cualquier modificación en la topología, se debe registrar un ticket de Cambio (RFC) en la plataforma ITSM antes de actualizar el mapa de red.
- **Línea base:** Retención inmutable de logs syslog/NetFlow por un mínimo de 6 meses y rotación de claves de administración cada 90 días.

Registros de Usuarios y Credenciales

- **Estándar:** Las contraseñas de dominio deben poseer una entropía alta, con una longitud mínima de 12 caracteres, forzando complejidad alfanumérica y bloqueo contra ataques de diccionario.
- **Directriz:** Se recomienda encarecidamente la adopción de gestores de contraseñas corporativos centralizados (Password Managers) para evitar el almacenamiento inseguro de credenciales.
- **Procedimiento:** El reseteo de contraseñas por parte de la Mesa de Ayuda debe seguir un protocolo Zero Trust, validando la identidad del usuario mediante preguntas de desafío (Challenge/Response).
- **Línea base:** Cambio obligatorio de contraseñas cada 90 días y retención de historial de las últimas 5 contraseñas para evitar su reutilización.

Impresoras Empresariales

- **Estándar:** Toda impresión de documentos debe requerir autenticación física del usuario frente al multifuncional mediante PIN o tarjeta RFID (Secure Print).

- **Directriz:** Se promueve la política de "Cero Papel"; se recomienda imprimir solo lo estrictamente necesario para minimizar la superficie de fuga física de información.
- **Procedimiento:** Para la baja o reubicación de impresoras, soporte técnico deberá ejecutar la "Guía de Sanitización", que detalla el borrado manual de la memoria caché y NVRAM.
- **Línea base:** Monitoreo centralizado del volumen de impresión por centro de costos y limpieza automática de la cola de impresión cada 12 horas.

Equipos de Cómputo - Laptops

- **Estándar:** El cifrado de disco completo (FDE) respaldado por hardware (chip TPM 2.0) debe estar habilitado de forma obligatoria en todos los equipos portátiles.
- **Directriz:** Se insta a los Energizadores a no conectar los equipos a redes Wi-Fi públicas abiertas; en caso extremo, solo debe hacerse con el túnel VPN Always-On activo.
- **Procedimiento:** Ante robo o extravío, el usuario debe reportarlo a la Mesa de Ayuda en menos de 2 horas para activar el protocolo de bloqueo de cuenta y borrado remoto (Wipe).
- **Línea base:** Instalación obligatoria del agente de seguridad (EDR/Antivirus) y configuración de actualizaciones automáticas de parches del sistema operativo.

Herramientas de Administración Remota

- **Estándar:** El uso de protocolos de administración (RDP, SSH) queda estrictamente prohibido desde redes públicas; solo se permite a través de una conexión VPN segura o Bastion Host.
- **Directriz:** Se recomienda que las sesiones de soporte técnico remoto a los usuarios finales (Help Desk) sean de tipo interactivas, requiriendo autorización explícita en pantalla.
- **Procedimiento:** Para otorgar acceso remoto a un proveedor, se deberá habilitar la conexión temporal en el panel de control técnico, deshabilitándose automáticamente al terminar la ventana de soporte.
- **Línea base:** Cierre forzado de puertos de administración y desconexión automática de la sesión remota tras 10 minutos de inactividad de periféricos.

Servidores Físicos y Virtuales

- **Estándar:** El acceso al hardware en el Data Center debe estar ineludiblemente restringido mediante control de acceso dual (biometría y llave/tarjeta física).
- **Directriz:** Se aconseja que la infraestructura virtual esté microsegmentada, aislando los servidores por tipo de servicio (ej. Bases de datos separadas de Aplicaciones) en VLANs independientes.
- **Procedimiento:** Para la protección de datos, TI ejecutará la guía de respaldos semanales completos (Bare-Metal), validando la consistencia de la imagen resultante.
- **Línea base:** Aplicación estricta de la plantilla de bastionado de seguridad (OS Hardening) basada en controles CIS antes de liberar cualquier servidor a producción.

Intranet

- **Estándar:** Todo el tráfico hacia la Intranet corporativa debe transitar obligatoriamente bajo el protocolo criptográfico HTTPS (TLS 1.2 o superior).
- **Directriz:** Se exhorta a los dueños de contenido de cada departamento a revisar y actualizar la vigencia de sus publicaciones el primer día hábil de cada mes.
- **Procedimiento:** Para subir un nuevo documento, el autor debe asignarle una categoría en el gestor de contenido (CMS), definiendo su nivel de clasificación para el repositorio.
- **Línea base:** Denegación de acceso por defecto (Deny-All) a cualquier solicitud web proveniente de usuarios o direcciones IP externas a la red corporativa.

Documentación y Procesos

- **Estándar:** Todos los documentos corporativos críticos deben integrar una marca de agua y etiqueta de metadatos (DLP) indicando explícitamente su nivel de confidencialidad.
- **Directriz:** Se recomienda la digitalización inmediata de archivos físicos (Legacy) para mitigar el riesgo de deterioro, pérdida o acceso no autorizado en archiveros.
- **Procedimiento:** Para solicitar la desclasificación o destrucción de un documento sensible, se pedirá autorización al Oficial de Cumplimiento, procediendo a su borrado lógico o trituración física (Nivel P-4).
- **Línea base:** Registro inicial y obligatorio de todos los activos de información en el inventario oficial, asignando a un responsable directo (Dueño del Activo).

Activos Externos

Servicios de Nube (SaaS/PaaS)

- **Estándar:** El acceso a cualquier plataforma en la nube debe efectuarse mediante federación de identidades (SSO), Autenticación Multifactor (MFA) y cifrado en tránsito (TLS).
- **Directriz:** Se recomienda evaluar anualmente que los proveedores Cloud mantengan vigentes sus certificaciones internacionales de seguridad (ISO 27001, SOC 2 Nivel II).
- **Procedimiento:** El proceso de alta y baja de usuarios debe ejecutarse mediante un flujo formal de autorización desde la Mesa de Servicio del área de TI.
- **Línea base:** Revisión trimestral obligatoria de cuentas inactivas y revocación de permisos y accesos huérfanos en las consolas administrativas.

Enlaces de Internet (ISPs)

- **Estándar:** La totalidad del tráfico de entrada y salida debe ser canalizado y filtrado por Firewalls corporativos de Nueva Generación con Inspección Profunda de Paquetes (DPI).
- **Directriz:** Para asegurar la alta disponibilidad de las operaciones, se recomienda implementar una arquitectura SD-WAN con redundancia de proveedores ISP (Failover).
- **Procedimiento:** Ante latencia crítica o caída del enlace primario, el NOC ejecutará el protocolo de escalamiento técnico directo con el centro de soporte del proveedor.
- **Línea base:** Monitoreo telemétrico 24/7 del ancho de banda y establecimiento de SLAs operativos de disponibilidad superiores al 99.9%.

Proveedores de Hosting Web

- **Estándar:** Los servidores expuestos a Internet público deben contar obligatoriamente con certificados de seguridad SSL/TLS válidos y renovados antes de su expiración.
- **Directriz:** Para mitigar ataques de inyección, se recomienda la implementación de un Firewall de Aplicaciones Web (WAF) en modo de prevención estricta.
- **Procedimiento:** El equipo de infraestructura ejecutará la ventana de mantenimiento mensual para la actualización de parches y revisión de vulnerabilidades en el código.
- **Línea base:** Ejecución de un escaneo automatizado de seguridad perimetral al menos una vez al mes (Vulnerability Scan).

Plataformas de Mensajería y Videoconferencia

- **Estándar:** Para discusiones de negocios es obligatorio el uso de cuentas corporativas integradas al dominio y protegidas por MFA.
- **Directriz:** Se prohíbe la generación de enlaces de reunión públicos sin contraseña; siempre debe evitarse compartir accesos sin un control riguroso.
- **Procedimiento:** Al agendar reuniones estratégicas, el organizador debe configurar obligatoriamente la "Sala de Espera" (Lobby) y autorizar manualmente a los participantes.
- **Línea base:** Restricción a nivel de Tenant para impedir accesos o grabación de sesiones por parte de usuarios con dominios no autorizados.

APIs de Servicios Financieros

- **Estándar:** La comunicación transaccional bancaria debe emplear tokens seguros de corta duración y autenticación estricta basada en OAuth 2.0 y mTLS.
- **Directriz:** Se recomienda aplicar reglas de lista blanca (IP Whitelisting) para limitar exhaustivamente las IPs externas que pueden consumir la API.
- **Procedimiento:** El equipo de Arquitectura de TI procederá a la rotación periódica de credenciales criptográficas (Secrets) y al monitoreo continuo del consumo transaccional.
- **Línea base:** Registro y almacenamiento inmutable (WORM) de logs transaccionales financieros por un periodo de retención mínimo legal de 1 año.

Servicios de Soporte Técnico de Fabricantes

- **Estándar:** El acceso a la red corporativa por parte de proveedores se efectuará exclusivamente mediante una VPN corporativa estrictamente controlada y segmentada.
- **Directriz:** Es obligatoria la práctica de supervisión sincrónica ("Shadowing") durante las sesiones remotas por parte de un ingeniero interno.
- **Procedimiento:** El proveedor externo debe realizar una solicitud formal y obtener autorización previa mediante un ticket antes de que se habilite el soporte externo.
- **Línea base:** Grabación centralizada de la sesión de soporte técnico y registro del historial de actividades y comandos realizados.

Nube de Respaldo (Cloud Backup)

- **Estándar:** Los volúmenes de respaldo deben ser cifrados bajo llave administrada por el cliente (E2EE) tanto en tránsito hacia la nube como en reposo.

- **Directriz:** Para asegurar la resiliencia contra Ransomware, se recomienda aplicar el principio 3-2-1 de backups (incluyendo una copia fuera de sitio aislada).
- **Procedimiento:** El área de infraestructura documentará y ejecutará pruebas periódicas de restauración de máquinas virtuales para certificar los Tiempos de Recuperación (RTO).
- **Línea base:** Ejecución de políticas de respaldo automático diario y validación automática semanal de la integridad del bloque de datos.

Gestores de Dominios (DNS)

- **Estándar:** Es obligatoria la implementación de extensiones de seguridad (DNSSEC) para garantizar la autenticidad e integridad en la resolución de la marca en internet.
- **Directriz:** Se recomienda restringir el panel de administración del registrador, asegurándolo con Autenticación Multifactor (MFA) por hardware.
- **Procedimiento:** Toda modificación en los registros DNS requiere una Solicitud de Cambio (RFC) mediante aprobación formal para evitar secuestros de dominio.
- **Línea base:** Ejecución de una auditoría trimestral para depurar registros DNS huérfanos y prevenir la toma de subdominios (Subdomain Takeover).

Plataformas de Reclutamiento y Selección

- **Estándar:** El tratamiento de datos de candidatos debe cumplir estrictamente con los lineamientos de privacidad dictados por la legislación vigente (LFPDPPP).
- **Directriz:** Se instruye a minimizar la recolección de datos sensibles; no solicitar información médica o biométrica en las primeras fases del reclutamiento.
- **Procedimiento:** Para el manejo de datos de candidatos no seleccionados, se ejecutará la eliminación segura de expedientes digitales al terminar el periodo de gracia.
- **Línea base:** Establecimiento de un ciclo de vida de los datos, configurando una retención máxima de información de 12 meses.

Canales de Redes Sociales Corporativas

- **Estándar:** El acceso a los perfiles institucionales debe estar restringido mediante el uso de cuentas corporativas oficiales aseguradas con MFA.
- **Directriz:** Se recomienda el uso de gestores centralizados (ej. Hootsuite) para evitar compartir contraseñas nativas entre el equipo de redes sociales.
- **Procedimiento:** La publicación de contenido oficial debe seguir un flujo de revisión y aprobación digital visado por la Gerencia Comercial o Relaciones Públicas.
- **Línea base:** Cambio obligatorio de credenciales y rotación de tokens de API cada 90 días o ante la baja de cualquier integrante del área.

Matriz RACI

Para asegurar el cumplimiento de las políticas previamente descritas, se define la siguiente matriz de asignación de roles.

R	Responsable - Quienes ejecutan operativamente la tarea o configuran el control.
A	Aprobador – Quienes rinden cuentas, autorizan y tienen la responsabilidad final.
C	Consultado - Quienes asesoran o validan la acción de forma previa.
I	Informado – Quienes son notificados formalmente sobre los resultados.

Actividad / Proceso	Director de TI (CIO)	Oficial de Seguridad (CISO)	Administrador de Sistemas	Usuario Final / Empleado	Proveedor Externo
Activos Internos					
Gestión de Bases de Datos	A	C	R	I	I
Mantenimiento de ERP	A	I	R	C	C
Monitoreo de Red	I	A	R	I	C
Cambio de Contraseñas	I	A	C	R	I
Impresión Segura	I	C	A	R	I
Cifrado de Laptops	A	C	R	I	I
Administración Remota	A	I	R	C	I
Respaldo de Servidores	A	I	R	I	C
Publicación en Intranet	I	I	A	R	I
Clasificación de Documentos	I	A	I	R	I
Activos Externos					
Servicios de Nube SaaS/PaaS	A	C	R	I	C
Enlaces de Internet ISPs	A	I	R	I	C
Proveedores de Hosting Web	A	C	R	I	C
Plataformas de Mensajería y Videoconferencia	A	I	R	C	I
APIs de Servicios Financieros	A	C	R	I	C
Servicios de Soporte Técnico de Fabricantes	I	A	R	I	R
Nube de Respaldo (Cloud Backup)	A	C	R	I	C

Gestores de Dominios DNS	A	C	R	I	I
Plataformas de Reclutamiento Y selección	I	C	I	R	C
Canales de Redes Sociales Corporativas	I	C	I	R	I

SECCIÓN 6 - Planificación

Activos seleccionados - análisis de amenaza y vulnerabilidad.

Activo Afectado y Política Relacionada	Amenaza	Vulnerabilidad	Consecuencia
1. Base de Datos (Política: Base de Datos)	Exfiltración o alteración maliciosa de información estructurada crítica.	Ausencia de algoritmos criptográficos a nivel de columna y falta de MFA.	Pérdida de confidencialidad de datos maestros y registros contables.
2. ERP SAP/Oracle (Política: ERP Corporativo)	Manipulación no autorizada de transacciones contables o fiscales.	Falta de revisión periódica en la segregación de funciones (SoD).	Fraude financiero interno, errores de timbrado de CFDI y multas.
3. Monitoreo de Red (Política: Monitoreo de Red)	Alteración maliciosa de umbrales de alerta o visibilidad de tráfico.	Accesos administrativos expuestos sin restricción IP ni MFA forzado.	Ceguera operativa de TI ante ciberataques incidentes o caídas de red.
4. Credenciales (Política: Registros de Usuarios)	Secuestro de sesión, phishing o fuerza bruta.	Uso de contraseñas de baja entropía y falta de almacenes centralizados.	Compromiso de identidades legítimas y libre movimiento lateral en la red.
5. Impresoras (Política: Impresoras)	Fuga o interceptación de documentación en formato físico clasificado.	Impresión directa automatizada sin validación y almacenamiento en caché local.	Acceso no autorizado de terceros a datos corporativos residuales.
6. Laptops (Política: Equipos de Cómputo)	Compromiso lógico o físico de endpoints por robo, pérdida o malware.	Discos locales expuestos sin cifrar y uso de redes públicas sin túnel.	Fuga masiva de propiedad intelectual y acceso ilegítimo al perímetro.
7. Administración Remota (Política: Herramientas Remotas)	Establecimiento de conexiones externas maliciosas (Backdoors).	Consolas activas sin túnel seguro e inactividad de sesión prolongada.	Toma de control técnico total de servidores y computadoras por atacantes.

8. Servidores (Política: Servidores Físicos/Virtuales)	Compromiso sistémico de la infraestructura central y ransomware.	Omisión de bastionado operativo y segmentación de red laxa.	Interrupción total de los servicios operativos de manufactura y ERP.
9. Intranet(Política: Intranet)	Intercepción de tráfico confidencial interno corporativo.	Uso de protocolos HTTP no cifrados y accesos externos permitidos.	Filtración hacia el internet de directrices estratégicas o manuales privados.
10. Documentación (Política: Documentación y Procesos)	Alteración, filtración o pérdida del know-how y propiedad intelectual.	Falta de marcas de agua dinámicas, digitalización o inventarios oficiales.	Pérdida de continuidad operativa e incumplimientos graves de calidad ISO.
11. Servicios Nube (Política: Servicios SaaS/PaaS)	Robo de cuentas en la nube o fugas de datos en plataformas de terceros.	Autenticación basada en factores únicos y falta de auditorías al proveedor.	Compromiso de comunicaciones corporativas y herramientas del sector eléctrico.
12. Enlaces ISP (Política: Enlaces de Internet)	Ataques volumétricos de Denegación de Servicio (DDoS) o cortes de línea.	Carencia de firewalls perimetrales avanzados y enlaces redundantes.	Aislamiento digital de la empresa, pérdida de conectividad con clientes y paros.
13. Hosting Web(Política: Proveedores Hosting)	Modificación fraudulenta de la web pública o explotación de fallos OWASP.	Servidores sin Web Application Firewall (WAF) y omisión de parches.	Daño a la reputación digital pública e interceptación de datos de clientes.
14. Videoconferencias (Política: Plataformas de Mensajería)	Intercepción o intrusión de terceros no autorizados en reuniones.	Compartición de URLs públicas sin contraseña ni control de accesos.	Fuga de información altamente confidencial sobre estrategias o personal.
15. APIs Financieras (Política: APIs Financieras)	Robo de tokens lógicos o consumo fraudulento de	Autenticación básica desactualizada y falta de restricciones por IP.	Alteración en conciliaciones, afectaciones contables y facturación falsa.

	servicios financieros.		
16. Soporte Técnico (Política: Soporte de Fabricantes)	Uso indebido o malicioso de privilegios delegados a terceros externos.	Accesos remotos sin supervisión sincrónica ni bitácoras formalizadas.	Modificaciones operativas no autorizadas o implantación de brechas en planta.
17. Cloud Backup (Política: Nube de Respaldo)	Pérdida, secuestro o corrupción de los respaldos de información remotos.	Datos en tránsito sin cifrar y ausencia de pruebas periódicas de recuperación.	Imposibilidad de restaurar la operación del negocio ante incidentes catastróficos.
18. DNS (Política: Gestores de Dominios)	Secuestro de dominios o suplantación de identidad digital.	Ausencia de extensiones DNSSEC y falta de MFA en el panel registrador.	Redirección maliciosa de clientes y empleados hacia entornos fraudulentos.
19. Reclutamiento (Política: Plataformas de Reclutamiento)	Exposición, robo o filtración accidental de datos personales de aspirantes.	Recolección excesiva de Datos Personales de Identidad Personal (PII) y retención laxa.	Sanciones legales, multas millonarias por el INAI e incumplimiento de la LFPDPPP.
20. Redes Sociales (Política: Canales Redes Sociales)	Uso fraudulento, hackeo de cuentas corporativas oficiales o desinformación.	Credenciales compartidas de forma directa y falta de gestión centralizada.	Daño reputacional severo a la marca corporativa de Viakon ante el mercado.

Escala de Probabilidad e Impacto.

Probabilidad

Impacto.

Índice	Valor	Índice	Valor
MUY BAJO	1	INSIGNIFICANTE	1
BAJO	2	MENOR	2
MODERADO	3	SIGNIFICATIVO	3
PROBABLE	4	MAYOR	4
CASI SEGURO	5	SEVERO	5

Escala y criterios de interpretación y niveles de riesgo.

La estrategia de administración está directamente afectada por el rango del riesgo de cada activo, lo que implica contar con una estrategia correspondiente al nivel del Riesgo.

Rango de Riesgo	Nivel de Riesgo	Estrategia de Administración
1 a 4	Bajo	Aceptar: Monitorear periódicamente sin inversión de recursos adicionales.
5 a 9	Medio	Mitigar / Transferir: Aplicar controles operativos estándar o seguros.
10 a 14	Alto	Mitigar: Implementar controles técnicos prioritarios en el corto plazo.
15 a 19	Muy Alto	Mitigar / Evitar: Intervención inmediata; rediseño de procesos o infraestructura.
20 a 25	Extremo	Eliminar / Mitigar Crítico: Detener o modificar la actividad de riesgo de inmediato; aplicar controles de seguridad avanzados de forma obligatoria.

Cálculo de Riesgo.

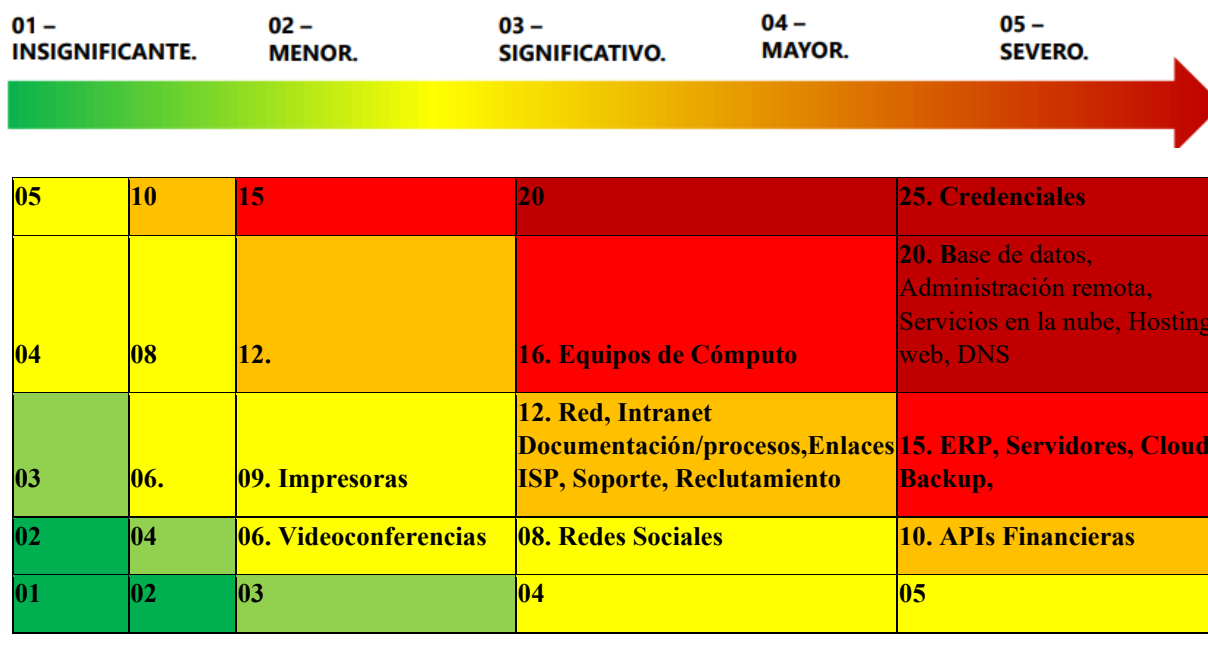
El cálculo se realizó por medio de la siguiente fórmula:

$$\text{Riesgo (R)} = \text{Probabilidad (P)} * \text{Impacto (I)}$$

Activo Afectado y Política Relacionada	P	I	R	Nivel de Riesgo	Estrategia de Administración
1. Base de Datos (Política Base de Datos)	4	5	20	Extremo	Eliminar / Mitigar
2. ERP SAP/Oracle (Política ERP Corporativo)	3	5	15	Muy Alto	Mitigar
3. Monitoreo de Red (Política Monitoreo de Red)	3	4	12	Alto	Mitigar
4. Credenciales (Política Registros de Usuarios)	5	5	25	Extremo	Eliminar / Mitigar
5. Impresoras (Política Impresoras)	3	3	9	Medio	Mitigar
6. Laptops (Política Equipos de Cómputo)	4	4	16	Muy Alto	Mitigar
7. Admón. Remota (Política Herramientas Remotas)	4	5	20	Extremo	Eliminar / Mitigar
8. Servidores (Política Servidores Físicos/Virtuales)	3	5	15	Muy Alto	Mitigar
9. Intranet (Política Intranet)	3	4	12	Alto	Mitigar
10. Documentación (Política Documentación y Procesos)	3	4	12	Alto	Mitigar

11. Servicios Nube (Política Servicios SaaS/PaaS)	4	5	20	Extremo	Eliminar / Mitigar
12. Enlaces ISP (Política Enlaces de Internet)	3	4	12	Alto	Mitigar / Transferir
13. Hosting Web (Política Proveedores Hosting)	4	5	20	Extremo	Mitigar
14. Videoconferencias (Política Plataformas de Mensajería)	2	3	6	Medio	Mitigar
15. APIs Financieras (Política APIs Financieras)	2	5	10	Alto	Eliminar / Mitigar
16. Soporte Técnico (Política Soporte de Fabricantes)	3	4	12	Alto	Mitigar
17. Cloud Backup (Política Nube de Respaldo)	3	5	15	Muy Alto	Mitigar
18. DNS (Política Gestores de Dominios)	4	5	20	Extremo	Eliminar / Mitigar
19. Reclutamiento (Política Plataformas de Reclutamiento)	3	4	12	Alto	Mitigar
20. Redes Sociales (Política Canales Redes Sociales)	2	4	8	Medio	Mitigar

Matriz de Riesgo.



Mecanismos de Control.

Activo Afectado y Política Relacionada	Explicación del Mecanismo de Control y Clasificación
1. Base de Datos (Política Base de Datos)	Cifrado AES-256 en columnas sensibles y MFA administrativo (Preventivo); Monitoreo de consultas anómalas en SIEM (Detectivo); respaldos cada 4 horas (Correctivo).
2. ERP SAP/Oracle (Política ERP Corporativo)	Autenticación robusta de doble factor y segregación de perfiles (Preventivo); flujos de aprobación gerencial (Preventivo); cierre automático de sesión por inactividad (Preventivo).
3. Monitoreo de Red (Política Monitoreo de Red)	Whitelisting de IPs administrativas y MFA obligado (Preventivo); bitácoras y registros de cambios en la topología (Detectivo); retención inmutable de logs syslog por 6 meses (Detectivo).
4. Credenciales (Política Registros de Usuarios)	Longitud mínima de 12 caracteres y cambio obligatorio cada 90 días (Preventivo); despliegue de gestor de contraseñas corporativo (Preventivo); validación de identidad en resets (Correctivo).
5. Impresoras (Política Impresoras)	Retención de trabajos de impresión mediante liberación por tarjeta RFID o PIN (Preventivo); concientización de impresión selectiva (Preventivo); purga manual/automatizada de la memoria caché (Correctivo).
6. Laptops (Política Equipos de Cómputo)	Cifrado Full Disk (FDE) vía TPM 2.0 y uso obligado de túnel VPN corporativo (Preventivo); agentes antivirus/EDR en endpoints (Preventivo/Detectivo); ejecución remota de protocolo de borrado técnico Kill Pill (Correctivo).
7. Admón. Remota (Política Herramientas Remotas)	Conexión remota permitida únicamente bajo canal cifrado VPN corporativo (Preventivo); desconexión forzada tras 10 minutos de inactividad (Preventivo); supervisión obligatoria en pantalla por el usuario final (Detectivo).
8. Servidores (Política Servidores Físicos/Virtuales)	Restricción física mediante biometría y aplicación de guías de bastionado CIS (Preventivo); aislamiento lógico de servicios críticos mediante VLANs (Preventivo); ejecución de copias semanales completas (Correctivo).

9. Intranet (Política Intranet)	Cifrado forzado en tránsito mediante protocolo HTTPS bajo HSTS y bloqueo externo por defecto (Preventivo); validación mensual de vigencia por dueños de proceso (Detectivo); control transaccional e historial en CMS (Detectivo).
10. Documentación (Política Documentación y Procesos)	Registro mandatorio en inventario maestro oficial y etiquetado con marcas de agua de confidencialidad (Preventivo); digitalización de archivos físicos (Preventivo); flujo formal de desclasificación y destrucción segura (Correctivo).
11. Servicios Nube (Política Servicios SaaS/PaaS)	Federación de identidad (SSO), cifrado TLS y MFA obligatorio (Preventivo); procesos institucionales de altas/bajas gobernados por TI (Preventivo); evaluación de informes de cumplimiento SOC 2 / ISO 27001 (Detectivo); revisión trimestral de accesos (Detectivo).
12. Enlaces ISP (Política Enlaces de Internet)	Inspección profunda de paquetes (DPI) vía firewalls perimetrales y redundancia física con ruteo dinámico BGP (Preventivo); monitoreo 24/7 de ancho de banda (Detectivo); contratos SLA Anti-DDoS y protocolos de escalamiento ante caídas (Correctivo).
13. Hosting Web (Política Proveedores Hosting)	Certificados SSL/TLS vigentes e implementación activa de un firewall de aplicación WAF (Preventivo); actualización periódica de parches y plugins (Preventivo); escaneo automatizado mensual de vulnerabilidades (Detectivo).
14. Videoconferencias (Política Plataformas de Mensajería)	Uso obligatorio de cuentas institucionales federadas con MFA y geobloqueos (Preventivo); inhabilitación por completo de enlaces públicos anónimos (Preventivo); configuración de reuniones con sala de espera y validación de participantes (Detectivo).
15. APIs Financieras (Política APIs Financieras)	Autenticación robusta basada en OAuth 2.0 / Mutual TLS y rotación de llaves (Preventivo); whitelisting estricto de IPs consumidoras a nivel Gateway (Preventivo); logs centralizados e inmutables bajo política WORM por 1 año (Detectivo).
16. Soporte Técnico (Política Soporte de Fabricantes)	Accesos únicamente por VPNs SSL limitadas a través de Bastion Hosts y aprobación formal previa (Preventivo); supervisión obligatoria en tiempo real (Shadowing) (Detectivo); grabación integral en video e historial inmutable de comandos (Detectivo).
17. Cloud Backup (Política Nube de Respaldo)	Cifrado de extremo a extremo (E2EE) y almacenamiento inmutable con separación lógica (Air-gap) (Preventivo); estrategia de respaldo automático diario basada en el principio 3-2-1 (Preventivo); simulacros formales de DRP y validación técnica de integridad (Correctivo).

18. DNS (Política Gestores de Dominios)	Implementación estricta de extensiones de seguridad DNSSEC y panel blindado con MFA (Preventivo); control y autorización previa para cambios de infraestructura (Preventivo); auditoría trimestral de depuración de registros (Detectivo).
19. Reclutamiento (Política Plataformas de Reclutamiento)	Integración obligatoria de avisos de privacidad y minimización estricta en la recolección de datos sensibles (Preventivo); ejecución mensual automatizada de purga para datos huérfanos (Correctivo); retención máxima establecida e inquebrantable de 12 meses (Correctivo).
20. Redes Sociales (Política Canales Redes Sociales)	Acceso exclusivo vía roles RBAC asociados a identidades con MFA (Preventivo); integración única obligatoria en plataforma unificada de Marketing (Preventivo); rotación técnica de credenciales cada 90 días (Preventivo); flujos formales de revisión y aprobación previa de contenidos (Detectivo).

SECCIÓN 7 - Soporte

Justificación Ejecutiva: ¿Qué estamos trabajando y por qué es necesario?

Comunicado a la Dirección de Viakon (Grupo Xignux)

¿Qué estamos trabajando?

En esta fase del proyecto estamos implementando la Cláusula 7 (Soporte) del estándar ISO/IEC 27001. Esto significa que estamos dotando al Sistema de Gestión de Seguridad de la Información (SGSI) de los recursos humanos, tecnológicos y de conocimiento necesarios para que funcione correctamente en el piso de manufactura y en las áreas administrativas.

¿Por qué es necesario?

La tecnología por sí sola no detiene los incidentes. El factor humano sigue siendo el eslabón más vulnerable en la cadena de seguridad. Es indispensable asegurar que nuestros "Energizadores" (operarios, técnicos y administrativos) comprendan su rol en la protección de los activos de Viakon. Sin un soporte adecuado (recursos, competencia y concientización), los controles técnicos implementados en servidores y bases de datos pueden ser evadidos mediante ingeniería social o malas prácticas operativas (ej. contraseñas compartidas o sesiones abiertas en planta).

Beneficios para el Negocio (ROI de Seguridad):

1. **Reducción de Riesgos Operativos:** Disminución en la probabilidad de paros de línea por infecciones de malware o accesos no autorizados en terminales compartidas.
2. **Eficiencia Normativa:** Asegura que la información documentada (manuales y procedimientos) esté controlada y siempre disponible para auditorías de calidad (ISO 9001/14001).
3. **Cultura de Prevención:** Transforma a los Energizadores en la primera línea de defensa de la empresa, protegiendo la confidencialidad de nuestras fórmulas, datos financieros y registros de personal.



Minuta De Reunión Corporativa

Empresa: Viakon

Departamento: Dirección de Administración y TI

Sistema: Sistema de Gestión de Seguridad de la Información (SGSI)

Detalle de la sesión	Información
Asunto	Definición Operativa - Cláusula 7: Soporte (Recursos, Competencia y Concientización)
Fecha	6 de mayo de 2026
Sede	DCN Tower / Sala de Juntas Principal (Modalidad Híbrida)
Horario	Inicio: 10:00 hrs. Término: 11:00 hrs.
Elaborado por	

1. Objetivo de la Sesión

Establecer y documentar las directrices de la Cláusula 7 (Soporte) del SGSI, garantizando la asignación de recursos tecnológicos, y estructurando los programas de competencia, concientización y control de información documentada dirigidos específicamente a los operarios, técnicos de mantenimiento y personal de planta.

2. Participantes (Comité de Implementación SGSI)

Nombre	Rol Asignado en el Proyecto	Asistencia
Montelongo Martínez Laura Ivon	Líder de Proyecto / Oficial de Seguridad (CISO)	✓
Benites Rangel Cesar Yahir	Especialista en Infraestructura TI	✓
Cortes Beltrán Carol Elizabeth	Coordinadora de Cumplimiento Normativo	✓
Guerra Ramírez América Fabiola	Analista de Gestión de Riesgos	✓
Larios Guerra Gustavo Michael	Administrador de Sistemas y Redes	✓
Puente Luna Bruno Axel	Arquitecto de Servicios en la Nube	✓
Rodríguez Moreno Cristian Alejandro	Analista de Ciberseguridad	✓

3. Invitados clave (Área Operativa y Técnica)

Rol Representativo	Área	Asistencia
Gerente de Producción (Invitado)	Manufactura y Operaciones	✓
Coordinador de Mantenimiento (Invitado)	Operarios y Técnicos de Piso	✓

4. Temas Tratados y Acuerdos Formales

- **Punto 1: Asignación de Recursos y Entorno Técnico (7.1)**
 - Discusión: El Comité evaluó las vulnerabilidades físicas en las HMI (Human-Machine Interface), escáneres de inventario y terminales compartidas en el piso de producción.
 - Acuerdo: Aprobación de despliegue de políticas GPO (Group Policy Object) para forzar el bloqueo automático de sesiones tras 5 minutos de inactividad. Se restringe administrativamente el montaje de dispositivos USB masivos en todos los equipos de manufactura.
- **Punto 2: Competencia, Concientización y Comunicación Técnica (7.2, 7.3 y 7.4)**
 - Discusión: Necesidad de erradicar prácticas de riesgo como contraseñas en post-its o el préstamo de credenciales en los cambios de turno.
 - Acuerdo: Implementación inmediata del "Programa de Concientización Técnica de Piso". Se utilizarán "Charlas de Seguridad" (Safety Talks) de 5 minutos antes de iniciar operaciones, utilizando infografías de alto impacto visual.
- **Punto 3: Información Documentada para Operarios (7.5)**
 - Discusión: Disponibilidad de manuales sin comprometer el control de versiones ni la fuga de información.
 - Acuerdo: Migración hacia un repositorio centralizado. Las copias impresas en planta llevarán marca de agua dinámica, clasificación de confidencialidad e identificador de versión controlado por el equipo de TI.

4. Plan de Acción y Responsabilidades

Tarea / Compromiso	Responsables	Estatus
Diseñar cápsulas de concientización visual (infografías) para los tableros de las líneas de producción.	Cortes Beltrán C. E. Guerra Ramírez A. F.	En proceso
Imprimir, clasificar y distribuir manuales técnicos seguros en las estaciones operativas (HMI).	Benites Rangel C. Y. Larios Guerra G. M. Puente Luna B. A.	Pendiente
Auditar y configurar el bloqueo automático de sesiones en las terminales compartidas por operarios.	Montelongo Martínez L. I. Rodríguez Moreno C. A.	Pendiente
Validar con Operaciones los horarios para las "Charlas de Seguridad" en los cambios de turno.	Montelongo Martínez L. I.	Pendiente

5. Próxima Reunión de Seguimiento

- **Fecha programada:** viernes, 22 de mayo de 2026.
- **Objetivo:** Revisar el material didáctico diseñado para los operarios técnicos y validar el despliegue del bloqueo de sesiones en terminales compartidas.

7. Cierre y Aprobación

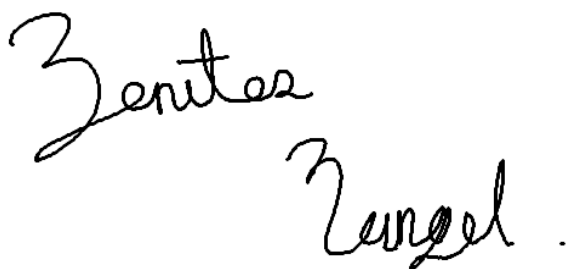
Se dan por leídos y aprobados los lineamientos normativos de la Cláusula 7 para su integración oficial en el manual maestro del SGSI de Viakon.

Firmas de Conformidad del Comité:



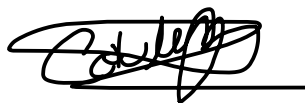
Montelongo Martínez Laura Ivon

Líder de Proyecto / CISO



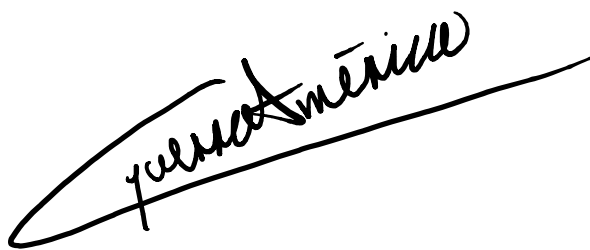
Benites Rangel Cesar Yahir

Especialista en Infraestructura TI



Cortés Beltrán Carol Elizabeth

Coordinadora de Cumplimiento Normativo

A handwritten signature in black ink, reading "Fabiola Guerra Ramírez", written diagonally across the page.

Guerra Ramírez América Fabiola

Analista de Gestión de Riesgos

A handwritten signature in black ink, reading "Michael", written diagonally across the page.

Larios Guerra Gustavo Michael

Administrador de Sistemas y Redes

A handwritten signature in black ink, reading "Bruno", written diagonally across the page.

Puente Luna Bruno Axel

Arquitecto de Servicios en la Nube

A handwritten signature in black ink, reading "C. Rodríguez", written diagonally across the page.

Rodríguez Moreno Cristian Alejandro

Analista de Cibersegurida

PRESENTACIÓN



Gestión de seguridad

Administración y TI

Benites Rangel Cesar Yahir
Cortés Beltrán Carol Elizabeth
Larios Guerra Gustavo Michael
Guerra Ramírez América Fabiola
Montelongo Martínez Laura Ivon
Rodríguez Moreno Cristian Alejandro
Puentes Luna Bruno Axel



Acercas de la Empresa

Viakon, marca de Viakable (Grupo Xignux), es una empresa de clase mundial que **fabrica conductores eléctricos** seguros y eficientes mediante tecnología de vanguardia.

Todas sus operaciones cuentan con certificaciones ISO-9001 e ISO-14001, garantizando calidad y durabilidad en el mercado.



Sección 1: Alcance

Área enfocada: Administración y TI.

Objetivo: Establecer los requisitos críticos para la protección de los activos de información gestionados por las direcciones del área de administración y TI.



Ámbito de aplicación

- Gestión de Datos Maestros de Activos: Protección de información digital y física, y registros de cumplimiento legal (STPS).
- Gestión Financiera y Contable: Seguridad en el procesamiento de presupuestos, determinación de impuestos, dispersiones bancarias y emisión de CFDI (Timbrado), asegurando que la información financiera sea inalterable y privada.
- Control Documental y Normativo: Resguardo de los manuales de procedimientos, auditorías operativas y certificaciones de industria vinculadas a la calidad (ISO-9001/14001).
- Seguridad Física y Control de Accesos: Protección de los datos derivados de los sistemas de videovigilancia, bitácoras de proveedores y registros biométricos de acceso en las plantas de manufactura.

Organigrama

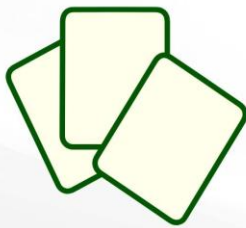


Sección 2: Referencias Normativas.

- Norma principal obligatoria: **ISO/IEC 27000** (vocabulario y conceptos SGSI)
- Compatibilidad con sistemas existentes: **ISO 9001** (Calidad) e **ISO 14001** (Medio Ambiente)
- Todo el SGSI adopta la Estructura de Alto Nivel (HLS/Anexo SL) para integración total



Sección 3: Términos y Condiciones



- Glosario clave del SGSI: Activo, Amenaza, Riesgo, CID, Confidencialidad, Integridad, Disponibilidad
- Conceptos operativos: Evaluación de riesgos, Tratamiento de riesgos, Plan de continuidad del negocio, Inventario de activos
- Base normativa: ISO/IEC 27001 como referencia de certificación mundial



Sección 4: Contexto de la Organización



Activos Internos clave: Bases de datos, ERP (SAP/Oracle), servidores, laptops, intranet, credenciales de usuarios



Activos Externos clave: Servicios en la nube (SaaS/PaaS), ISPs, APIs financieras, plataformas de videoconferencia, cloud backup



Todos clasificados por criticidad para el negocio

Sección 5: Liderazgo

- Política General: Marco de protección de activos con compromiso de Alta Dirección
- La dirección asigna presupuesto, revisa el sistema y promueve cultura de "Seguridad Primero"
- Matriz RACI: Roles definidos – Director TI (A), CISO (C/A), Administrador Sistemas (R), Usuario Final (R/C), Proveedor (C)

Aplica a todo el personal interno, proveedores y socios comerciales

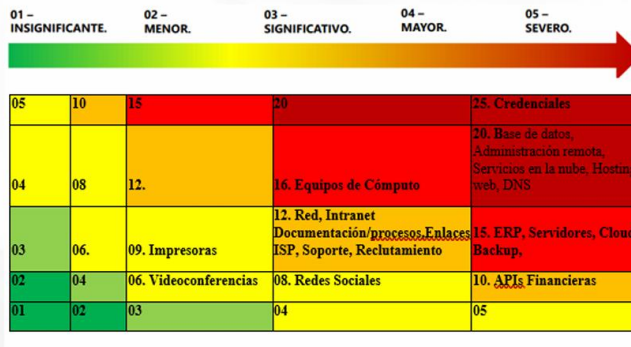


Sección 6: Planificación

Matriz de riesgo

Nivel	Puntaje	Riesgos	Mitigaciones
Extremo	20-25	Credenciales débiles, acceso no autorizado a BD, admin remota, SaaS, hosting web, APIs financieras, DNS	MFA, cifrado, auditorías, VPN, segmentación
Muy Alto	15-16	ERP manipulado, servidores comprometidos, cloud backup, robo de laptops, redes sociales	VPN, auditorías, cifrado, segmentación

Matriz de riesgo



Activo Afectado y Política Relacionada	Explicación del Mecanismo de Control y Clasificación
1. Base de Datos (Política Base de Datos)	Cifrado AES-256 en columnas sensibles y MFA administrativo (Preventivo); monitoreo de consultas anómalas en SIEM (Detectivo); respaldos cada 4 horas (Correctivo).
2. ERP SAP/Oracle (Política ERP Corporativo)	Autenticación robusta de doble factor y segregación de perfiles (Preventivo); flujos de aprobación gerencial (Preventivo); cierre automático de sesión por inactividad (Preventivo).
3. Monitoreo de Red (Política Monitoreo de Red)	Whitelisting de IPs administrativas y MFA obligado (Preventivo); bitácoras y registros de cambios en la topología (Detectivo); retención inmutable de logs syslog por 6 meses (Detectivo).
4. Credenciales (Política Registros de Usuarios)	Longitud mínima de 12 caracteres y cambio obligatorio cada 90 días (Preventivo); despliegue de gestor de contraseñas corporativo (Preventivo); validación de identidad en resateos (Correctivo).
5. Impresoras (Política Impresoras)	Retención de trabajos de impresión mediante liberación por tarjeta RFID o PIN (Preventivo); concientización de impresión selectiva (Preventivo); purga manual/automatizada de la memoria caché (Correctivo).
6. Laptops (Política Equipos de Computo)	Cifrado Full Disk (FDE) vía TPM 2.0 y uso obligado de túnel VPN corporativo (Preventivo); agentes antivirus/EDR en endpoints (Preventivo/Detectivo); ejecución remota de protocolo de borrado técnico Kill Pill (Correctivo).

El núcleo de nuestra estrategia preventiva. Esta matriz cuantifica la exposición de los activos críticos de Viakon evaluando la Probabilidad vs. Impacto de cada amenaza. Cada nivel de riesgo identificado cuenta con una estrategia de tratamiento asignada (Mitigar, Transferir, Eliminar o Aceptar) y controles específicos como MFA, cifrado y segmentación. Esto garantiza que la inversión en ciberseguridad sea inteligente, priorizando la protección de la infraestructura operativa y los datos financieros.

Sección 7: Liderazgo

Minuta del 6 de mayo

Asunto: Definición Estratégica – Cláusula 6: Planificación y Evaluación de Riesgos

Fecha: 6 de mayo de 2026

Objetivo de la reunión

Establecer y documentar las directrices de la Cláusula 7 (Soporte) del SGSI, garantizando la asignación de recursos tecnológicos, y estructurando los programas de competencia, concientización y control de información documentada dirigidos específicamente a los operarios, técnicos de mantenimiento y personal de planta.

Temas tratados y resoluciones

Asignación de Recursos y Entorno Técnico (7.1)

Competencia, Concientización y Comunicación Técnica (7.2, 7.3 y 7.4)

Información Documentada para Operarios (7.5)

Plan de acción

Diseñar cápsulas de concientización visual (Infografías) para los tableros de las líneas de producción.

Imprimir, clasificar y distribuir manuales técnicos seguros en las estaciones operativas (HMI).

Auditar y configurar el bloqueo automático de sesiones en las terminales compartidas por operarios.

Validar con Operaciones los horarios para las "Charlas de Seguridad" en los cambios de turno.

Conclusiones

La estructuración de las cláusulas 1 a la 7 de la norma ISO 27001:2022 ha permitido establecer los cimientos estratégicos y operativos del Sistema de Gestión de Seguridad de la Información (SGSI) en Viakon. A través de este desarrollo, logramos alinear la protección de los activos de información con los objetivos del negocio, garantizando el compromiso de la Alta Dirección y definiendo una metodología ágil y proactiva para el tratamiento de riesgos.

Más allá de la infraestructura tecnológica, este marco normativo integra al factor humano como un pilar fundamental, asegurando los recursos, la documentación estandarizada y la concientización necesaria para todo el personal, desde el área corporativa hasta los operarios de planta. Con esta sólida fase de planificación y soporte, Viakon consolida una verdadera cultura de ciberseguridad, dejando el sistema completamente preparado para su ejecución, monitoreo y mejora continua.

SECCIÓN 8 - Operación

Política seleccionada: Servidores Físicos y Virtuales

1. Plan (Planear)

- En esta fase se establecen los objetivos, riesgos, controles y recursos necesarios para garantizar la seguridad de los servidores físicos y virtuales dentro de la organización.

Objetivos

- Proteger el acceso físico y lógico a los servidores críticos.
- Implementar segmentación de red mediante VLANs para aislar servicios sensibles.
- Garantizar la disponibilidad e integridad de la información mediante respaldos confiables.
- Aplicar configuraciones seguras (hardening) en sistemas operativos Windows y Linux.
- Reducir vulnerabilidades y riesgos asociados a accesos no autorizados y fallos operativos.

Riesgos identificados

- Acceso físico no autorizado al centro de datos.
- Pérdida de información por fallos de hardware o errores humanos.
- Propagación lateral de ataques debido a una segmentación deficiente.
- Explotación de vulnerabilidades por configuraciones inseguras.
- Interrupción de servicios críticos por fallas de seguridad.

Actividades planificadas

- Instalar controles biométricos, cámaras de vigilancia y cerraduras electrónicas en el área de servidores.
- Definir VLANs según el tipo de servicio para mejorar el aislamiento de red:
 - Base de datos
 - Aplicaciones
 - Servicios web
 - Administración y monitoreo
- Implementar un calendario automatizado de respaldos semanales y pruebas de restauración.
- Aplicar políticas de hardening en servidores Windows y Linux.
- Configurar firewalls, antivirus y sistemas de detección de intrusos.
- Establecer monitoreo continuo de eventos y registros de seguridad.
- Definir responsables de monitoreo, mantenimiento y respuesta a incidentes.

Configuraciones de hardening

- Deshabilitación de puertos y servicios innecesarios.
- Restricción de accesos remotos no autorizados.
- Configuración segura de contraseñas y políticas de autenticación.
- Actualización y parchado periódico de sistemas operativos.
- Configuración de firewall local.
- Activación de registros y auditorías de seguridad.
- Implementación de antivirus y herramientas EDR.

Recursos necesarios

- Software de respaldo y recuperación.
- Herramientas de virtualización.
- Equipos biométricos y sistemas de videovigilancia.
- Firewalls y herramientas de monitoreo.
- Personal de TI y seguridad informática capacitado.
- Documentación de procedimientos y políticas de seguridad.

Indicadores y métricas

Indicador	Meta
Respaldos exitosos	$\geq 98\%$
Accesos físicos no autorizados	0
Cumplimiento de hardening	100%
Tiempo de recuperación ante fallos (RTO)	≤ 2 horas
Disponibilidad de servidores	99.9%
Vulnerabilidades críticas detectadas	0

Normativas y buenas prácticas relacionadas

- ISO 27001
- NIST Cybersecurity Framework
- CIS Benchmarks
- Políticas internas de seguridad de la organización

2. Do (Hacer)

En esta fase se implementan las medidas y controles definidos durante la planificación.

Acciones realizadas

- Se instalaron lectores biométricos, cámaras de vigilancia y controles de acceso físico.
- Se configuraron VLANs para separar y proteger los servicios críticos.
- Se implementó una estrategia de respaldos completos semanales con validación automática de integridad.
- Se realizaron pruebas periódicas de restauración de información.
- Se deshabilitaron servicios y puertos innecesarios en los servidores.
- Se aplicaron actualizaciones de seguridad y configuraciones seguras en Windows y Linux.
- Se configuraron firewalls y sistemas de monitoreo de eventos.
- Se habilitó el registro centralizado de logs y alertas de seguridad.

Evidencias

- Bitácoras de acceso físico.
- Reportes de respaldos exitosos.
- Resultados de pruebas de restauración.
- Documentación de VLANs implementadas.
- Checklist de hardening aplicado.
- Reportes de monitoreo y eventos de seguridad.
- Evidencias de actualización y parchado de servidores.

3. Check (Verificar)

En esta etapa se evalúa la efectividad de los controles implementados y el cumplimiento de los objetivos de seguridad establecidos.

Actividades de verificación

- Auditoría de accesos físicos al centro de datos.
- Validación de restauración de respaldos.
- Escaneo de vulnerabilidades en servidores físicos y virtuales.
- Revisión de segmentación de red y reglas de firewall.
- Evaluación del cumplimiento de hardening.
- Monitoreo de logs y eventos de seguridad.
- Comparación de resultados obtenidos contra los indicadores definidos.

Resultados esperados

- Reducción de accesos no autorizados.
- Respalos funcionales y recuperables.
- Disminución de vulnerabilidades críticas.
- Mejor aislamiento entre servicios.
- Mayor disponibilidad de los servidores.

- Detección temprana de incidentes de seguridad.

Métricas de evaluación

Métrica	Resultado esperado
Respaldos exitosos	100%
Accesos físicos no autorizados	0
Vulnerabilidades críticas	Reducción significativa
Cumplimiento de hardening	100%
Disponibilidad de servicios	≥ 99.9%

4. Act (Actuar)

Con base en los resultados obtenidos durante la verificación, se implementan acciones correctivas y mejoras continuas para fortalecer la seguridad de los servidores.

Acciones de mejora

- Actualizar periódicamente las políticas de seguridad.
- Mejorar los mecanismos de autenticación física y lógica.
- Automatizar monitoreo, alertas y generación de reportes.
- Implementar revisiones mensuales de hardening.
- Corregir configuraciones inseguras detectadas en auditorías.
- Optimizar procedimientos de respaldo y recuperación.
- Ajustar reglas de segmentación y firewall según nuevas amenazas.
- Realizar simulacros de recuperación ante desastres.
- Capacitar continuamente al personal en buenas prácticas de seguridad informática.

Mejora continua

La aplicación del ciclo PDCA permite fortalecer continuamente la seguridad de los servidores físicos y virtuales, optimizando la disponibilidad, integridad y confidencialidad de la información. Asimismo, contribuye a reducir riesgos relacionados con accesos no autorizados, pérdida de datos, vulnerabilidades críticas y fallas operativas, garantizando una gestión alineada con estándares y buenas prácticas de seguridad de la información.

SECCIÓN 9 - Evaluación del desempeño

Objetivo de la Auditoría

Evaluar la eficacia del Sistema de Gestión de Seguridad de la Información (SGSI) implementado en Viakon, verificando la conformidad de los controles técnicos y administrativos con los requisitos de la norma ISO/IEC 27001:2022 y las políticas internas.

Formato de Entrevista de Auditoría

Este instrumento evidencia la interacción real con los dueños de procesos para validar los controles técnicos.

- Fecha: 6 de mayo de 2026
- Auditor Líder: Laura Ivon Montelongo Martínez
- Auditado: Administrador de Base de Datos (DBA)
- Objetivo: Verificar la retención de logs y exportación de alertas al SIEM corporativo.

Transcripción de Evidencia:

Auditor: "De acuerdo con la política BD-01, todas las consultas a tablas con información financiera deben ser auditadas. ¿Puede mostrarme en la consola de Splunk los registros de actividad del último mes correspondientes a los usuarios sysadmin?"

Auditado: "Actualmente, Splunk solo está ingiriendo logs perimetrales del firewall y del Active Directory. Los logs transaccionales del motor SQL se guardan de forma local en el servidor de base de datos debido a un problema de licenciamiento en la cuota de ingesta de datos."

Auditor: "¿Cuánto tiempo de retención tienen esos logs locales y quién tiene acceso a ellos?"

Auditado: "Se sobrescriben cada 7 días por falta de espacio en disco. Como DBA, yo tengo acceso directo a la carpeta contenedora."

Conclusión de la Entrevista: Se confirma la vulnerabilidad. No hay segregación de funciones en la auditoría de logs (el DBA audita sus propios accesos) y no se cumple la retención mínima de 6 meses exigida por la norma.

I. GESTIÓN DE ACTIVOS INTERNOS

1. Cédula de Auditoría: Base de Datos

Objetivo de Control: Garantizar la Confidencialidad e Integridad de la información crítica mediante algoritmos criptográficos y control de acceso privilegiado.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
BD-01	Verificación de cifrado TDE y enmascaramiento dinámico de datos (DDM) en columnas críticas.	Extracción de configuración del motor SQL. Tablas financieras cifradas bajo estándar AES-256.	CUMPLE	Bajo

BD-02	Autenticación multifactor (MFA) obligatoria para roles sysadmin y db_owner.	Análisis de logs de acceso administrativo cruzados con plataforma de identidad corporativa.	CUMPLE	Bajo
BD-03	Trazabilidad de consultas y exfiltración de datos mediante SIEM.	Auditoría de dashboards en Splunk; no se encontraron registros de búsquedas SPL (Search Processing Language) para el último mes.	NO CUMPLE	Alto
BD-04	Flujo de autorización para escalamiento de privilegios (Just-In-Time Access).	Tickets de gestión de accesos (IAM) cotejados con matriz de dueños de información.	CUMPLE	Bajo
BD-05	Resiliencia de datos: Backups incrementales cada 4h y rotación criptográfica.	Repositorio de llaves (Key Vault) auditable y consola de almacenamiento inmutable.	CUMPLE	Bajo

Dictamen Final: CUMPLIMIENTO PARCIAL. Se requiere integrar los logs de auditoría de BD al sistema SIEM de inmediato para garantizar la trazabilidad de consultas anómalas.

2. Cédula de Auditoría: ERP Corporativo (SAP/Oracle)

Objetivo de Control: Mitigar riesgos de fraude interno y asegurar la inalterabilidad de los registros contables y fiscales.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
ERP-01	Políticas de acceso condicional y MFA habilitadas en el inicio de sesión.	Prueba de inicio de sesión desde segmento de red no confiable (fuera de VPN).	CUMPLE	Bajo
ERP-02	Análisis de conflictos de Segregación de Funciones (SoD) en roles de finanzas.	Reporte generado desde el módulo GRC (Governance, Risk, and Compliance) del ERP.	CUMPLE	Bajo

ERP-03	Aprobación gerencial trazable para alta y modificación de perfiles.	Muestreo estadístico de 10 altas; el 100% cuenta con firma digital autorizada.	CUMPLE	Bajo
ERP-04	Finalización forzada de sesiones TCP/UDP por inactividad.	Parámetros del servidor de aplicaciones validan el cierre exacto a los 15 minutos.	CUMPLE	Bajo
ERP-05	Ciclo de vida de contraseñas alineado a políticas de complejidad corporativa.	Revisión de parámetros de seguridad globales en la instancia del sistema.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Los controles del entorno financiero operan dentro de los márgenes de riesgo aceptable.

3. Cédula de Auditoría: Software de Monitoreo de Red

Objetivo de Control: Mantener la integridad de los sistemas de alerta temprana y prevenir la ceguera operativa.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
RED-01	Control de acceso basado en red (NAC) y Whitelisting de IPs.	Revisión de Listas de Control de Acceso (ACLs) en los firewalls perimetrales.	CUMPLE	Bajo
RED-02	MFA forzado para perfiles con capacidad de alterar configuraciones del NOC.	Verificación de políticas del proveedor de identidad (IdP) para el grupo de red.	CUMPLE	Bajo
RED-03	Auditoría de umbrales y baselines de comportamiento anómalo.	Faltan firmas de revisión del último trimestre en las actas de operaciones de red.	CUMPLE PARCIAL	Medio
RED-04	Cumplimiento del marco ITIL para registro de cambios en topología.	Cruce de la bitácora del sistema de monitoreo vs. plataforma de Change Management.	CUMPLE	Bajo

RED-05	Retención inmutable de logs syslog/NetFlow por mínimo 6 meses.	Confirmación de cuotas de almacenamiento y políticas de archivado en el SIEM.	CUMPLE	Bajo
---------------	--	---	--------	------

Dictamen Final: CUMPLIMIENTO PARCIAL. Se emite observación para normalizar la periodicidad de las auditorías de umbrales.

4. Cédula de Auditoría: Registros de Usuarios y Credenciales

Objetivo de Control: Establecer un perímetro de identidad sólido contra ataques de fuerza bruta y movimiento lateral.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
USR-01	Directivas de contraseñas: entropía, longitud mínima (12) y bloqueo de diccionario.	Auditoría de configuración de Default Domain Policy en Active Directory.	CUMPLE	Bajo
USR-02	Implementación de bóvedas de contraseñas empresariales (PAM/Password Manager).	Métricas de telemetría de la herramienta indicando uso activo por el 90% de usuarios.	CUMPLE	Bajo
USR-03	Protocolo Zero Trust para recuperación y reseteo de identidades.	Auditoría de llamadas grabadas en Help Desk validando preguntas de desafío (Challenge/Response).	CUMPLE	Bajo
USR-04	Rotación forzada de secretos criptográficos a nivel usuario.	Extracción de reporte de expiración de contraseñas de la base de datos LDAP.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Arquitectura de identidad sólida y escalable.

5. Cédula de Auditoría: Impresoras Empresariales

Objetivo de Control: Prevenir la fuga de información clasificada en formato físico y asegurar auditoría de trabajos.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
IMP-01	Retención de trabajos de impresión (Secure Print) mediante autenticación RFID/PIN.	Prueba de penetración física y revisión de cola de impresión segura.	CUMPLE	Bajo
IMP-02	Monitoreo centralizado del uso de activos de impresión corporativos.	Dashboard del servidor de impresión validando volúmenes por centro de costos.	CUMPLE	Bajo
IMP-03	Sanitización lógica de medios de almacenamiento volátiles (Caché/NVRAM).	No existe un procedimiento estándar documentado ni logs de borrado en bitácoras de TI.	NO CUMPLE	Alto

Dictamen Final: CUMPLIMIENTO PARCIAL. Urge documentar y aplicar el procedimiento de purga de memoria en los multifuncionales para evitar recuperación de datos.

6. Cédula de Auditoría: Equipos de Cómputo - Laptops

Objetivo de Control: Asegurar los endpoints corporativos contra compromiso físico e infecciones de malware.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
LAP-01	Cifrado Full Disk Encryption (FDE) respaldado por chip TPM 2.0.	Consola de Endpoint Management confirma estatus 100% de dispositivos encriptados.	CUMPLE	Bajo
LAP-02	Restricción de red a nivel de host para conexiones Wi-Fi abiertas.	Directivas locales restringen tráfico no corporativo salvo que el túnel VPN esté activo.	CUMPLE	Bajo

LAP-03	Protocolo de respuesta a incidentes por pérdida de activos (Remote Wipe).	Simulación de incidente "Kill Pill"; borrado remoto exitoso en equipo de prueba.	CUMPLE	Bajo
LAP-04	Agentes de seguridad de nueva generación (EDR) y gestión de vulnerabilidades.	Estatus de cumplimiento de parches de SO y firmas de comportamiento anómalo.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Defensas de capa de endpoint operando al máximo rendimiento.

7. Cédula de Auditoría: Herramientas de Administración Remota

Objetivo de Control: Eliminar backdoors de soporte y restringir el control de activos a canales seguros.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
REM-01	Segmentación de red y uso obligatorio de túneles VPN IPsec/SSL.	Inspección de reglas de firewall; tráfico RDP (TCP 3389) bloqueado desde WAN.	CUMPLE	Bajo
REM-02	Interacción obligatoria y consentimiento del usuario final (Interactive Logon).	Sesiones remotas probadas requieren explícitamente autorización en pantalla.	CUMPLE	Bajo
REM-03	Aprovisionamiento y desaprovisionamiento de capacidades de soporte remoto.	Auditoría de grupos administrativos y permisos delegados en consola de TI.	CUMPLE	Bajo
REM-04	Control de sesiones inactivas para prevención de secuestro de sesión (Session Hijacking).	Configuración GPO aplicada forzando cierre tras 10 minutos de inactividad de mouse/teclado.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Superficie de ataque interno mitigada eficazmente.

8. Cédula de Auditoría: Servidores Físicos y Virtuales

Objetivo de Control: Mantener la resiliencia operativa y protección profunda del Centro de Datos.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
SRV-01	Controles físicos de acceso perimetral en Data Center (Biometría 2FA).	Revisión de logs del sistema CCTV y control de acceso físico de la planta.	CUMPLE	Bajo
SRV-02	Microsegmentación de infraestructura virtual a nivel hipervisor.	Auditoría de arquitectura vSwitch y reglas inter-VLAN.	CUMPLE	Bajo
SRV-03	Procedimientos operativos de contingencia y Backup Bare-Metal.	Reportes de ventanas de mantenimiento y actas de consistencia de imágenes.	CUMPLE	Bajo
SRV-04	Conformidad con estándares de bastionado del Center for Internet Security (CIS).	Escaneo de vulnerabilidades validando desactivación de servicios y puertos inseguros.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Centro de datos alineado a los requerimientos normativos ISO.

9. Cédula de Auditoría: Intranet

Objetivo de Control: Asegurar la transmisión y disponibilidad de los lineamientos estratégicos de los "Energizadores".

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
INT-01	Cifrado en tránsito forzado (HSTS) utilizando protocolos modernos (TLS 1.2/1.3).	Análisis del servidor web y confirmación de redirecciones 301 estrictas.	CUMPLE	Bajo
INT-02	Ciclo de vida de la información y validación de dueños de procesos.	Faltan actas formales de desclasificación y actualización en el departamento comercial.	CUMPLE PARCIAL	Medio

INT-03	Control de versiones y trazabilidad de publicación documental.	Sistema CMS de Intranet evidencia el historial de cambios y aprobadores.	CUMPLE	Bajo
INT-04	Restricción de acceso lógico y geofencing a IPs corporativas.	Intentos de conexión externa resultan en respuesta 403 Forbidden.	CUMPLE	Bajo

Dictamen Final: CUMPLIMIENTO PARCIAL. Se requiere definir un flujo automatizado para la revisión de caducidad del contenido de Intranet.

10. Cédula de Auditoría: Documentación y Procesos

Objetivo de Control: Implementar clasificación estructural (Data Classification) y prevención de fuga de datos (DLP).

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
DOC-01	Etiquetado visual y lógico de sensibilidad en activos de información (AIP/DLP).	Muestreo de contratos y manuales. Existen documentos financieros sin marcas de agua ni etiquetas.	NO CUMPLE	Alto
DOC-02	Mitigación de riesgos físicos mediante digitalización segura de archivos.	Proceso de escaneo de histórico validado en sitio con el equipo de control documental.	CUMPLE	Bajo
DOC-03	Procedimiento de sanitización y destrucción de medios físicos/digitales.	Certificados de destrucción de disco duro y trituración de papel nivel P-4 disponibles.	CUMPLE	Bajo
DOC-04	Inventario de activos alineado a la cláusula 8 de ISO 27001.	Registro maestro actualizado con propietarios, ubicación y nivel de criticidad.	CUMPLE	Bajo

Dictamen Final: CUMPLIMIENTO PARCIAL. Se requiere levantar No Conformidad Menor para regularizar el etiquetado de documentos heredados (Legacy).

II. GESTIÓN DE ACTIVOS EXTERNOS

11. Cédula de Auditoría: Servicios de Nube (SaaS/PaaS)

Objetivo de Control: Gestionar los riesgos de cadena de suministro y evaluar la postura de seguridad de terceros.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
NUB-01	Control de identidad federada (SSO) combinado con MFA.	Auditoría de integración SAML/OAuth en el panel de administración Cloud.	CUMPLE	Bajo
NUB-02	Evaluación del cumplimiento normativo del proveedor (Vendor Risk Management).	Informes SOC 2 Nivel II e ISO 27017 archivados y vigentes para proveedores críticos.	CUMPLE	Bajo
NUB-03	Flujos de aprovisionamiento (Provisioning) gobernados por TI.	Procesos JML (Joiner, Mover, Leaver) demostrados en consolas SaaS.	CUMPLE	Bajo
NUB-04	Revocación periódica y auditoría de privilegios huérfanos (Over-privileged accounts).	Minutas de comité trimestral de revisión de accesos presentadas sin discrepancias.	CUMPLE	Bajo

Dictamen Final: CUMPLE. El entorno SaaS opera bajo una gobernanza de identidad estricta.

12. Cédula de Auditoría: Enlaces de Internet (ISPs)

Objetivo de Control: Asegurar alta resiliencia y filtrado avanzado de tráfico de salida e ingreso.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
ISP-01	Inspección Profunda de Paquetes (DPI) y descifrado SSL en el borde.	Análisis de reglas del Next-Generation Firewall (NGFW) corporativo.	CUMPLE	Bajo

ISP-02	Arquitectura de alta disponibilidad (HA) de red de área amplia (SD-WAN).	Ruteo dinámico (BGP) y configuraciones de failover verificados operativamente.	CUMPLE	Bajo
ISP-03	SLAs de mitigación de ataques volumétricos (Anti-DDoS).	Contratos y anexos de nivel de servicio con proveedores ISP tier 1 validados.	CUMPLE	Bajo
ISP-04	Observabilidad 24/7 y telemetría de desempeño de ancho de banda.	Dashboard SNMP/WMI demostrando latencia y disponibilidad por encima del 99.9%.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Continuidad de servicios de telecomunicaciones robusta.

13. Cédula de Auditoría: Proveedores de Hosting Web

Objetivo de Control: Minimizar la superficie de ataque pública y proteger la reputación digital.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
WEB-01	Gestión de infraestructura de llave pública (PKI) para servicios web.	Análisis de certificados de producción. Ningún certificado expira en los próximos 30 días.	CUMPLE	Bajo
WEB-02	Despliegue de Web Application Firewall (WAF) en modo prevención.	Logs evidencian mitigación activa de inyecciones SQL y ataques Cross-Site Scripting.	CUMPLE	Bajo
WEB-03	Gestión de parches en componentes CMS, plugins y sistemas subyacentes.	Documentación de ventana de mantenimiento mensual; 0 parches críticos faltantes.	CUMPLE	Bajo

WEB-04	Pruebas de seguridad en aplicaciones dinámicas (DAST).	Reporte automatizado de escaneo mensual de vulnerabilidades sin riesgos altos.	CUMPLE	Bajo
---------------	--	--	--------	------

Dictamen Final: CUMPLE. Infraestructura web pública protegida y en cumplimiento con marcos de seguridad OWASP.

14. Cédula de Auditoría: Plataformas de Mensajería y Videoconferencia

Objetivo de Control: Prevenir la interceptación de reuniones estratégicas y la fuga de datos por canales de comunicación no estructurados.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
VID-01	Autenticación corporativa estricta e integración SSO.	Directivas globales de la plataforma limitan el uso exclusivo a identidades sincronizadas.	CUMPLE	Bajo
VID-02	Bloqueo de exposición de información vía enlaces anónimos.	Configuración maestra del Tenant inhabilita la generación de URL públicas sin autenticación.	CUMPLE	Bajo
VID-03	Controles de ingreso y salas de espera (Lobby) obligatorios.	Revisión de sesiones en vivo comprobando que participantes externos no evaden la sala de espera.	CUMPLE	Bajo
VID-04	Federación restringida y listas de confianza (Trusted Domains).	Interacciones directas B2B limitadas exclusivamente a dominios configurados por TI.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Canales de comunicación asegurados contra espionaje y exfiltración de datos.

15. Cédula de Auditoría: APIs de Servicios Financieros

Objetivo de Control: Garantizar la autenticidad e inalterabilidad del tráfico B2B para operaciones contables y bancarias.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
API-01	Autenticación robusta (OAuth 2.0 / Mutual TLS) para servicios REST/SOAP.	Revisión de código y arquitectura de integración documentada en el API Gateway.	CUMPLE	Bajo
API-02	Restricción de consumo a nivel de red (IP Whitelisting).	Configuración del Firewall de Aplicaciones bloquea peticiones de orígenes no declarados.	CUMPLE	Bajo
API-03	Gestión de ciclo de vida y rotación criptográfica de tokens (Secrets Management).	Evidencia de expiración automática de JWT y rotación de llaves del servicio.	CUMPLE	Bajo
API-04	Retención inmutable de telemetría transaccional para auditoría forense.	Logs centralizados asegurados bajo política Write-Once-Read-Many (WORM) por 365 días.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Interfaces financieras altamente aseguradas.

16. Cédula de Auditoría: Soporte Técnico de Fabricantes

Objetivo de Control: Controlar estrictamente el acceso de proveedores a la red industrial y administrativa.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
FAB-01	Acceso remoto externalizado mediante Bastion Hosts o VPNs limitadas.	Vendors acceden exclusivamente vía portal SSL VPN con perfil de red restringido a su activo.	CUMPLE	Bajo

FAB-02	Supervisión sincrónica de proveedores (Shadowing).	Falta evidencia documental del supervisor interno de Viakon en el 20% de las intervenciones del mes.	CUMPLE PARCIAL	Medio
FAB-03	Aprobación formal basada en ventana de mantenimiento autorizada.	Tickets del sistema ITSM validados con aprobación del responsable técnico del área.	CUMPLE	Bajo
FAB-04	Trazabilidad en video e historial de comandos de sesiones de terceros.	Grabaciones de sesión almacenadas centralmente por el software de acceso seguro.	CUMPLE	Bajo

Dictamen Final: CUMPLIMIENTO PARCIAL. Requerida campaña de concientización a líderes técnicos sobre el llenado estricto de bitácoras de supervisión.

17. Cédula de Auditoría: Nube de Respaldo (Cloud Backup)

Objetivo de Control: Asegurar la resiliencia operativa contra incidentes catastróficos, como ataques de Ransomware.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
BCK-01	Cifrado E2EE (End-to-End Encryption) previo al tránsito hacia Cloud.	Configuración del Agente de Respaldo demostrando llaves administradas por el cliente.	CUMPLE	Bajo
BCK-02	Conformidad con topología de respaldo 3-2-1 y separación lógica (Air-gap).	Arquitectura de almacenamiento inmutable validada en repositorios cloud externos.	CUMPLE	Bajo
BCK-03	Simulacros de Recuperación de Desastres (DRP) y cumplimiento de RTO/RPO.	Reporte ejecutivo del último simulacro; objetivos de tiempo y punto de recuperación logrados.	CUMPLE	Bajo
BCK-04	Verificación de integridad automatizada de bloques de respaldo (SureBackup).	Notificaciones del sistema confirmando arranque exitoso de máquinas virtuales desde el respaldo.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Capacidad de recuperación garantizada ante desastres.

18. Cédula de Auditoría: Gestores de Dominios (DNS)

Objetivo de Control: Proteger la identidad de la marca en internet previniendo ataques de suplantación de identidad (Spoofing) y secuestro.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
DNS-01	Implementación de extensiones de seguridad (DNSSEC).	Verificación pública demostrando firmas criptográficas de la zona correctas.	CUMPLE	Bajo
DNS-02	Protección contra secuestro de dominio (Domain Hijacking).	Consola del registrador auditada; cuenta de administrador maestra blindada con MFA.	CUMPLE	Bajo
DNS-03	Control de cambios formales para registros de infraestructura (MX/TXT/A).	Plataforma ITSM evidencia folios de autorización previos a modificaciones en producción.	CUMPLE	Bajo
DNS-04	Sanitización y limpieza de registros huérfanos propensos a Subdomain Takeover.	Bitácora trimestral de depuración de registros firmada por el arquitecto de TI.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Controles técnicos del dominio implementados según mejores prácticas.

19. Cédula de Auditoría: Plataformas de Reclutamiento y Selección

Objetivo de Control: Garantizar el cumplimiento legal y privacidad de datos sensibles asociados a procesos de capital humano.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
------------	---	---	-----------	--------

REC-01	Cumplimiento del marco normativo local de protección de datos (LFPDPPP).	Aviso de privacidad corporativo actualizado y aceptado en los portales de talento.	CUMPLE	Bajo
REC-02	Minimización en la recolección de Información de Identidad Personal (PII).	Formularios auditados; no solicitan datos médicos o biométricos en fases no requeridas.	CUMPLE	Bajo
REC-03	Eliminación segura (Data Sanitization) de candidatos no viables.	Revisión del Job programado en base de datos ejecutando purgas automáticas mensuales.	CUMPLE	Bajo
REC-04	Política de retención de datos limitada a 12 meses.	Consultas en base de datos confirman inexistencia de registros huérfanos anteriores a un año.	CUMPLE	Bajo

Dictamen Final: CUMPLE. Gestión de datos personales de candidatos altamente controlada y legalmente conforme.

20. Cédula de Auditoría: Canales de Redes Sociales Corporativas

Objetivo de Control: Mitigar riesgos reputacionales previniendo el compromiso de canales de comunicación públicos oficiales.

ID Control	Parámetro de Auditoría (Estándar Técnico)	Método de Comprobación y Evidencia Objetiva	Resultado	Riesgo
SOC-01	Acceso basado en roles (RBAC) y MFA en canales corporativos nativos.	Controles de seguridad de las plataformas (ej. Meta Business Manager) validados.	CUMPLE	Bajo
SOC-02	Consolidación de publicación mediante herramientas de gestión centralizada.	Integración y uso exclusivo de plataforma unificada para todo el equipo de Marketing.	CUMPLE	Bajo

SOC-03	Control y auditoría de flujo de publicación de contenidos.	Revisión de logs en plataforma demostrando el ciclo "Creación -> Revisión -> Aprobación".	CUMPLE	Bajo
SOC-04	Rotación periódica de credenciales compartidas o tokens de API de marketing.	Evidencia del gestor de contraseñas de TI validando la rotación en los últimos 90 días.	CUMPLE	Bajo

Clasificación de Hallazgos del SGSI

Derivado de la evaluación de las 20 cédulas de auditoría, se categorizan las desviaciones encontradas:

No Conformidades Mayores (Riesgo Crítico/Alto):

(NC-M-01) BD-03: Ausencia de trazabilidad y retención inmutable de logs en las bases de datos transaccionales, dejando un punto ciego ante exfiltración de información.

No Conformidades Menores (Riesgo Medio):

(NC-m-01) DOC-01: Documentación financiera e histórica ("Legacy") circulando sin marcas de agua ni etiquetas de clasificación (DLP), violando la política de control documental.

(NC-m-02) IMP-03: Falta de un procedimiento técnico de purga de memoria en multifuncionales, exponiendo datos residuales.

Observaciones (Riesgo Bajo, pero requieren atención):

(OBS-01) FAB-02: Relajamiento en el llenado de bitácoras de "Shadowing" al supervisar a proveedores externos durante soporte remoto.

(OBS-02) RED-03: Retraso administrativo en la firma de actas de revisión de umbrales del software de monitoreo de red.

Oportunidades de Mejora (Mejores prácticas recomendadas):

(OM-01) INT-02: Implementar un script automatizado en la Intranet corporativa que notifique a los dueños de contenido 15 días antes de que sus documentos expiren, eliminando la dependencia de revisión manual.

Conclusión General

Tras la revisión documental, entrevistas a dueños de procesos y simulación de pruebas técnicas, el SGSI de Viakon presenta un estado general de cumplimiento del 85%. El entorno demuestra una arquitectura de identidad sólida (Zero Trust) y resiliencia en la capa perimetral. Sin embargo, existen brechas en la retención de logs críticos (Base de datos y Endpoints físicos) que requieren atención inmediata.

Dictamen Final: CUMPLE. Canales digitales oficiales operando bajo políticas estrictas de ciberseguridad.

SECCIÓN 10 - Mejora

Registro de No Conformidad Mayor (Incidente de Seguridad)

ID de Incidente: INC-2026-054

Fecha y Hora de Detección: Miércoles 13 de mayo, 23:45 hrs.

Afectación principal: Confidencialidad y Disponibilidad.

Resumen Ejecutivo para la Alta Dirección

¿Qué ocurrió?

Se materializó una intrusión no autorizada en el núcleo de nuestra red corporativa de Viakon. Un actor de amenazas logró infiltrarse en nuestros sistemas, tomar control de herramientas de administración y extraer información de nuestras bases de datos antes de intentar sabotear la infraestructura interna mediante el despliegue de cargas destructivas.

¿Cómo ocurrió?

El atacante evadió nuestro perímetro de seguridad a través del factor humano. A pesar de contar con herramientas de Autenticación Multifactor (MFA), el intruso utilizó técnicas avanzadas de suplantación de identidad para "secuestrar" la sesión activa de un Energizador legítimo. Una vez dentro de la red, el atacante aprovechó que esta cuenta poseía privilegios excesivos (una falla en la segregación de funciones del ERP) para moverse lateralmente sin detonar las alarmas iniciales, escalando su acceso hasta nuestros servidores centrales.

Activos Críticos Afectados

1. **Infraestructura Operativa:** Terminales críticas de control en la planta de manufactura (inutilizadas temporalmente por corrupción de software).
2. **Sistemas Estratégicos:** Servidores centrales y bases de datos del ERP Corporativo (SAP/Oracle).
3. **Activos de Información:** Exposición y exfiltración de registros financieros, operativos y datos personales (maestros de activos y expedientes de Energizadores).

Cuantificación del Impacto (Business Impact)

El impacto de este incidente trascendió el departamento de TI, afectando múltiples dimensiones del negocio:

- **Impacto Operativo (Disponibilidad):** Interrupción de 4 horas y 15 minutos en las terminales de manufactura. Esto generó un retraso directo en la cadena de suministro y en las métricas de producción del turno correspondiente.
- **Impacto Legal y Normativo (Confidencialidad):** La exposición de datos de nuestros Energizadores detona un riesgo de cumplimiento legal frente a la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP). Esto nos obliga a ejecutar protocolos de notificación ante el INAI para mitigar posibles multas millonarias.
- **Impacto Financiero:** Costos operativos no planificados derivados de las horas-hombre invertidas por el equipo de respuesta a incidentes (CSIRT), la recuperación de respaldos y el análisis forense especializado.
- **Impacto Reputacional y de Calidad:** Afortunadamente, la contención en el minuto 14 (MTTD) evitó que el ataque llegara a los sistemas de clientes externos o proveedores, protegiendo nuestra reputación de marca y asegurando que las certificaciones ISO-9001 e ISO-14001 no se vean comprometidas de cara al mercado.

Análisis de Causa Raíz (RCA) e Incumplimiento de Políticas

La investigación forense determinó que el incidente se materializó debido a vulneraciones específicas a las normativas de nuestro SGSI:

1. **Herramientas de Administración Remota:** Se violó el Estándar que exige el uso estricto de conexiones VPN seguras.
2. **ERP Corporativo / Registros de Usuarios:** Deficiencia en la Directriz de "Revisión semestral de la segregación de funciones". La cuenta comprometida poseía privilegios excesivos (ausencia del Principio de Menor Privilegio).
3. **Base de Datos:** Inobservancia del Estándar que requiere "implementar cifrado a nivel de columna para datos sensibles", lo que permitió la sustracción de información en texto plano.
4. **Servidores Físicos y Virtuales:** Omisión en la aplicación estricta de la Línea base de seguridad del sistema operativo (Hardening), lo que facilitó el despliegue de cargas corruptivas en la infraestructura.

Contexto Técnico (Inteligencia de Amenazas):

El evento fue trazado a través de la Cyber Kill Chain y el Modelo Diamante de Análisis de Intrusiones. Se determinó que el uso de técnicas de Session Hijacking (Secuestro de Sesión) permitió al atacante saltar el perímetro. La investigación en el SIEM corporativo facilitó aislar las IPs maliciosas y revocar los accesos en tiempo real.

Plan de Acción Correctiva (CAP) y Contención

Para garantizar la Disponibilidad e Integridad de las operaciones, el Equipo de Respuesta a Incidentes (CSIRT) ejecutó las siguientes acciones:

- **Contención Inmediata:** Aislamiento de la VLAN de la planta de manufactura comprometida y revocación de todos los tokens de sesión activos desde el panel de control técnico.

- **Erradicación y Recuperación:** Para mitigar la corrupción de servidores, se invocó la Línea base de Base de Datos (respaldos incrementales de 4 horas) y el procedimiento de recuperación de Servidores Físicos/Virtuales, logrando restaurar la operatividad del ERP en el Tiempo Objetivo de Recuperación (RTO) definido.

Mejora Continua y Prevención (Actualización del SGSI)

En estricto apego al principio de Mejora Continua del estándar ISO 27001 (Cláusula 10), la Dirección de TI y Administración autoriza los siguientes ajustes operativos y estratégicos para evitar la recurrencia:

1. **Ajuste de Política - Refuerzo de Identidad (Zero Trust):** El MFA tradicional se actualizará. Ahora se exigirá una validación del estado del dispositivo (Device Posture) antes de otorgar acceso remoto a cualquier red de Viakon.
2. **Controles Técnicos - Hardening y Segmentación:** Se eleva la Directriz de Servidores a Estándar: "Todos los servidores virtuales críticos de manufactura y ERP deben estar obligatoriamente segmentados por VLANs restrictivas", limitando el movimiento lateral.
3. **Mejora de Procesos y Monitoreo:** La auditoría de registros de bases de datos pasará de ser una revisión "mensual" a un monitoreo automatizado en tiempo real. Además, se reestructurarán de inmediato los flujos de aprobación en el ERP para garantizar privilegios mínimos.
4. **Capacitación y Concientización:** Se desplegará una campaña interna obligatoria orientada a todos los "Energizadores" para prevenir el robo de credenciales, enfocándose en la identificación de ingeniería social y el manejo seguro de sesiones (Material de campaña adjunto en el Anexo de Prevención).

Indicadores de Rendimiento del Incidente (KPIs)

- **MTTD (Tiempo Medio de Detección):** 14 minutos. Resultado Positivo. El SOC demostró alta eficacia gracias a las alertas de anomalías en el tráfico de red.
- **MTTR (Tiempo Medio de Respuesta):** 4 horas y 15 minutos. Área de Oportunidad. Superó los umbrales de tolerancia. Como medida correctiva, se integrarán playbooks de respuesta automatizada (SOAR) con el objetivo de reducir este tiempo en un 60% para futuros eventos.



VIAKON
INNOVAMOS CON ENERGÍA

¡TU SESIÓN ES LA LLAVE! PROTÉGELA

Campaña Oficial de Prevención y
Ciberseguridad Viakon

TUS 3 REGLAS DE ORO:

Nadie en Viakon te pedirá jamás credenciales sensibles por ningún medio, si te lo solicitan, ¡Es un ataque!

- ✓ Cero Confianza
- ✓ Bloquea tu Sesión:
- ✓ Desconfía de la "Urgencia":

¡No permitas que comprometan
nuestra energía!



¿Detectaste un correo sospechoso o crees que tu sesión fue comprometida?
¡Repórtalo de inmediato a la Mesa de Ayuda de TI!

Dirección de Administración y TI | Innovamos con Energía Segura